BANK SOAL

CompTIA Security+ (SY0-701)

286 soal pilihan ganda + 12 soal performa (PBQ)

Dengan kunci jawaban dan pembahasan Bahasa Indonesia

Domain	Materi	Bobot
D1	General Security Concepts	12%
D2	Threats, Vulnerabilities, and Mitigations	22%
D3	Security Architecture	18%
D4	Security Operations	28%
D5	Security Program Management and Oversight	20%

Edisi 03 November 2026

Materi latihan mandiri — bukan soal resmi CompTIA dan tidak berafiliasi dengan CompTIA, Inc.

Cara Menggunakan Bank Soal Ini

- Kerjakan satu domain per sesi. Tutup bagian kunci jawaban sampai semua soal domain tersebut selesai dijawab.
- Beri tanda pada soal yang ragu. Setelah selesai, baca pembahasan bukan hanya untuk soal yang salah, tetapi juga yang benar karena kebetulan.
- Catat pola kesalahan: apakah karena tidak tahu istilah, salah membaca kata kunci (BEST/MOST/FIRST), atau kurang teliti pada skenario.
- Ulangi domain dengan skor terendah setelah 2–3 hari, lalu campur semua domain seminggu sekali.
- Seminggu sebelum ujian, gunakan quiz.html: mode Ujian Simulasi (90 soal, 90 menit) untuk melatih stamina dan manajemen waktu.
- Untuk PBQ, tulis jawaban di kertas terpisah lalu bandingkan dengan jawaban model. Fokus pada urutan langkah dan justifikasi.

Kata kunci ujian: BEST / MOST likely / FIRST / MINIMAL — empat kata ini sering menentukan pilihan mana yang benar ketika lebih dari satu opsi tampak masuk akal. Pilih opsi yang paling langsung menjawab skenario, bukan yang paling canggih.

BAGIAN I — SOAL

286 soal pilihan ganda, dikelompokkan per domain

Domain 1 — General Security Concepts (12%)

36 soal · objektif: 1.1, 1.2, 1.3, 1.4

1. A security team deploys a badge reader and biometric scanner at the data center entrance so that only authorized staff can enter. Which control category and control type does this BEST describe?

Objektif 1.1 · Konsep

- **A.** Managerial, preventive
- **B.** Technical, preventive
- **C.** Physical, detective
- **D.** Operational, deterrent

2. Which of the following is the BEST example of a managerial control?

Objektif 1.1 · Definisi

- **A.** An annual risk assessment performed by the security committee
- **B.** A motion sensor that triggers an alarm after hours
- **C.** A honeypot placed in the DMZ to attract attackers
- **D.** A firewall rule that blocks inbound RDP traffic

3. A company wants to discourage employees from attempting to tailgate into a restricted floor. Management installs highly visible cameras, warning signs, and a guard station at the elevator lobby, even though the door itself is already badge-controlled. Which control type is being added?

Objektif 1.1 · Skenario

- **A.** Corrective
- **B.** Compensating
- **C.** Deterrent
- **D.** Detective

4. A hospital runs a legacy MRI workstation that cannot be patched because the vendor no longer supports the operating system. The security team places the workstation on an isolated VLAN with strict firewall rules and restricts access to a jump host. Which control type is this?

Objektif 1.1 · Skenario

- **A.** Directive
- **B.** Corrective
- **C.** Preventive
- **D.** Compensating

5. After a ransomware incident, the team wipes the affected servers and restores data from the previous night's backup. Which control type did the restore represent?

Objektif 1.1 · Skenario

- **A.** Detective
- **B.** Corrective
- **C.** Directive
- **D.** Deterrent

6. Which control type is represented by a policy that states "employees must lock their screens when leaving their desks"?

Objektif 1.1 · Definisi

- **A.** Detective
- **B.** Compensating
- **C.** Directive
- **D.** Physical

7. An attacker modifies a wire transfer record in a database. The bank later uses SHA-256 hashes stored alongside each record to prove the data was altered. Which security property is being protected?

Objektif 1.2 · Skenario

- **A.** Confidentiality
- **B.** Integrity
- **C.** Availability
- **D.** Non-repudiation

8. Which combination correctly maps the AAA components to their purpose?

Objektif 1.2 · Definisi

- **A.** Authentication encrypts traffic, authorization records activity, accounting proves identity
- **B.** Authentication proves identity, authorization grants access, accounting records activity
- **C.** Authentication grants access, authorization proves identity, accounting encrypts traffic
- **D.** Authentication records activity, authorization proves identity, accounting grants access

9. A user signs in with a username, password, and a code from an authenticator app. The system then checks that the user's role permits access to the payroll module. Which two AAA phases are described?

Objektif 1.2 · Skenario

- **A.** Authentication and authorization
- **B.** Identification and accounting
- **C.** Authorization and accounting
- **D.** Accounting and authorization

10. In a zero trust architecture, which component makes the decision about whether a request should be granted?

Objektif 1.2 · Skenario

- **A.** Data plane
- **B.** Policy enforcement point
- **C.** Policy administrator
- **D.** Policy engine

11. A company divides its internal network into many small zones so that a compromised web server cannot reach the database subnet directly. Each zone enforces its own least-privilege rules. Which zero trust concept is this?

Objektif 1.2 · Skenario

- **A.** Security through obscurity
- **B.** Network address translation
- **C.** Implicit trust zone
- **D.** Microsegmentation

12. A security team places a fake file named `payroll_master.xlsx` on a file server and alerts whenever it is opened. Which technique is being used?

Objektif 1.2 · Skenario

- **A.** Honeytoken
- **B.** Sinkhole
- **C.** Sandbox
- **D.** Honeypot

13. Which activity BEST describes a gap analysis?

Objektif 1.2 · Definisi

- **A.** Testing whether backups can be restored within the RTO
- **B.** Reviewing firewall rules for unused entries
- **C.** Comparing the current security posture against a desired framework or standard to identify missing controls
- **D.** Scanning the network for unpatched hosts

14. Before approving a change to the production VPN concentrator, the change advisory board asks: "If the change fails, how do we get back to the previous state within 30 minutes?" Which change management element does this question address?

Objektif 1.3 · Skenario

- **A.** Stakeholder approval
- **B.** Impact analysis
- **C.** Backout plan
- **D.** Maintenance window

15. A developer wants to push an emergency patch at 2 p.m. on a Tuesday. The security manager requires a documented approval, a tested result in staging, and notification to all stakeholders before the change is applied. Which process is being enforced?

Objektif 1.3 · Skenario

- **A.** Configuration baseline
- **B.** Incident response
- **C.** Change management
- **D.** Vulnerability scanning

16. A digital signature provides which set of security properties?

Objektif 1.4 · Definisi

- **A.** Confidentiality, integrity, and availability
- **B.** Integrity, authentication, and non-repudiation
- **C.** Confidentiality, authentication, and accounting
- **D.** Availability, non-repudiation, and authorization

17. A company encrypts its backup tapes and stores a copy of the encryption keys with a trusted third party so that data can be recovered if the administrator leaves. Which concept is this?

Objektif 1.4 · Skenario

- **A.** Key rotation
- **B.** Key escrow
- **C.** Key stretching
- **D.** Key exchange

18. Which statement correctly distinguishes a TPM from an HSM?

Objektif 1.4 · Perbandingan

A. A TPM stores certificates only; an HSM stores passwords only

B. A TPM is a dedicated appliance for high-volume transaction cryptography; an HSM is a chip soldered to a motherboard

C. A TPM is a chip that stores keys and measurements on a single host; an HSM is a hardened appliance or service that performs cryptographic operations for many systems

D. Both are software libraries used to generate certificates

19. An administrator must verify whether a certificate was revoked without downloading the entire revocation list. Which mechanism should be used?

Objektif 1.4 · Skenario

A. OCSP

B. Trust anchor

C. CSR

D. CRL

20. Why is a unique random salt added to each password before hashing?

Objektif 1.4 · Definisi

A. To prevent identical passwords from producing identical hashes and to defeat precomputed rainbow tables

B. To encrypt the password with the server's public key

C. To allow the password to be reversed by the administrator

D. To shorten the hash output

21. Which technique is designed to make brute-force attacks against stored passwords slower by repeatedly applying a hash function?

Objektif 1.4 · Definisi

A. Steganography

B. Salting

C. Key stretching

D. Tokenization

22. Which statement about hashing and encryption is CORRECT?

Objektif 1.4 · Perbandingan

A. Hashing requires a shared secret key

B. Hashing is reversible with the correct key; encryption is not

C. Hashing is a one-way function used for integrity; encryption is reversible and used for confidentiality

D. Both provide confidentiality

23. A company stores transaction records in a distributed ledger where each block contains the hash of the previous block and is replicated across nodes. Which property does this design primarily provide?

Objektif 1.4 · Skenario

A. Tamper-evident integrity through chaining

B. Faster transaction processing

C. Automatic key rotation

D. Confidentiality of the records

24. An organization wants full-disk encryption keys to be sealed to the hardware and released only when the boot measurements match a known-good state. Which technology is MOST appropriate?

Objektif 1.4 · Skenario

- **A.** HSM
- **B.** TPM
- **C.** KMS
- **D.** Secure enclave

25. Why do most TLS connections use asymmetric cryptography only during the handshake?

Objektif 1.4 · Perbandingan

- **A.** Because asymmetric algorithms cannot encrypt data
- **B.** Because symmetric encryption is much faster for bulk data transfer
- **C.** Because asymmetric keys are always public
- **D.** Because symmetric keys cannot be rotated

26. A stolen laptop is recovered. Investigators find the disk was protected with BitLocker, but a single sensitive file copied to a USB drive was readable. Which encryption scope would have protected that file?

Objektif 1.4 · Skenario

- **A.** File-level encryption
- **B.** Database encryption
- **C.** Full-disk encryption
- **D.** Partition encryption

27. Which protocol pairing is CORRECT for protecting email contents end to end?

Objektif 1.4 · Pemetaan

- **A.** S/MIME for email, IPsec for network layer
- **B.** TLS for email storage, SSH for web traffic
- **C.** DNSSEC for email, SFTP for web traffic
- **D.** HTTPS for email, SNMPv3 for file transfer

28. Which technique replaces sensitive data with a non-sensitive placeholder that maps back to the original value in a secure vault?

Objektif 1.4 · Perbandingan

- **A.** Tokenization
- **B.** Steganography
- **C.** Hashing
- **D.** Data masking

29. An attacker finds two different documents that produce the same MD5 hash and uses this to replace a legitimate file undetected. Which cryptographic weakness was exploited?

Objektif 1.4 · Skenario

- **A.** Collision
- **B.** Rainbow table
- **C.** Brute force
- **D.** Downgrade attack

30. A client and server negotiate TLS, but an on-path attacker forces them to use TLS 1.0 with weak ciphers. Which attack is described?

Objektif 1.4 · Skenario

- **A.** Downgrade attack
- **B.** Replay attack
- **C.** Pass-the-hash
- **D.** Birthday attack

31. A root certificate authority's private key is compromised. What is the MOST immediate risk?

Objektif 1.4 · Skenario

- **A.** All leaf certificates can no longer be encrypted
- **B.** Attackers can issue trusted certificates for any domain, enabling impersonation
- **C.** All hashed passwords become reversible
- **D.** OCSP responders stop working automatically

32. A data center uses two sets of doors with an interlocking mechanism: the first door must close before the second opens, preventing piggybacking. What is this called?

Objektif 1.2 · Skenario

- **A.** Bollard
- **B.** Access control vestibule
- **C.** Faraday cage
- **D.** Mantrap sensor

33. Which physical control is specifically designed to prevent a vehicle from ramming a building entrance?

Objektif 1.2 · Definisi

- **A.** Motion sensor
- **B.** Proximity reader
- **C.** Lighting
- **D.** Bollards

34. A SOC wants to detect attackers early by exposing a decoy server with fake credentials and monitoring all interaction with it. Which two concepts are combined here?

Objektif 1.2 · Skenario

- **A.** VLAN and NAC
- **B.** Honeypot and honeytoken
- **C.** Sandbox and WAF
- **D.** IDS and DLP

35. A critical zero-day forces administrators to apply an emergency patch outside the normal approval cycle. Which action keeps the change management process intact?

Objektif 1.3 · Skenario

- **A.** Apply the patch immediately, then document it and obtain retrospective approval from the change advisory board
- **B.** Skip documentation because the change is urgent
- **C.** Wait for the next monthly change window regardless of risk
- **D.** Let the administrator approve their own change without review

36. Which document provides the step-by-step tasks, responsible roles, and verification checks for applying a security patch?

Objektif 1.3 · Skenario

A. Risk register

B. Standard operating procedure

C. Acceptable use policy

D. Business impact analysis

Domain 2 — Threats, Vulnerabilities, and Mitigations (22%)

74 soal · objektif: 2.1, 2.2, 2.3, 2.4, 2.5

1. A group has spent two years developing custom malware and has repeatedly targeted government research networks in multiple countries. The group is well funded, patient, and interested in stealing intellectual property rather than money. Which threat actor does this BEST describe?

Objektif 2.1 · Skenario

- **A.** Insider threat
- **B.** Hacktivist
- **C.** Nation-state
- **D.** Unskilled attacker

2. An attacker defaces a company website with a political message and leaks internal emails to protest the company's supply contracts. Which motivation BEST explains this behavior?

Objektif 2.1 · Skenario

- **A.** Ideology
- **B.** Revenge
- **C.** Financial gain
- **D.** Espionage

3. A systems administrator resigns and, during the last week of employment, copies the customer database to a personal cloud drive. Which threat actor category applies?

Objektif 2.1 · Skenario

- **A.** Insider threat
- **B.** Shadow IT
- **C.** Hacktivist
- **D.** Organized crime

4. A criminal group operates a ransomware-as-a-service platform, recruits affiliates, and demands payment in cryptocurrency. Which threat actor is described?

Objektif 2.1 · Skenario

- **A.** Unskilled attacker
- **B.** Nation-state
- **C.** Organized crime
- **D.** Hacktivist

5. A marketing team signs up for an unsanctioned cloud file-sharing service to collaborate with an agency, bypassing IT review. Which term describes this situation?

Objektif 2.1 · Skenario

- **A.** Insider fraud
- **B.** Data sovereignty
- **C.** Shadow IT
- **D.** Supply chain attack

6. An individual with limited technical skill downloads a ready-made exploit kit and runs it against random IP addresses. Which term BEST describes this actor?

Objektif 2.1 · Skenario

- **A.** Insider threat
- **B.** Organized crime
- **C.** Advanced persistent threat
- **D.** Unskilled attacker

7. Which attribute MOST clearly distinguishes a nation-state actor from organized crime?

Objektif 2.1 · Perbandingan

- **A.** The use of malware
- **B.** The level of resources, sophistication, and patience in pursuing strategic goals
- **C.** The use of the internet
- **D.** The targeting of private companies

8. Which pair correctly matches a threat actor with its PRIMARY motivation?

Objektif 2.1 · Definisi

- **A.** Organized crime — monetary gain
- **B.** Nation-state — website defacement for fun
- **C.** Hacktivist — financial fraud
- **D.** Insider — ideological protest

9. Attackers compromise a managed service provider (MSP) and use its remote management tooling to deploy malware to dozens of the MSP's customers at once. Which threat vector is this?

Objektif 2.2 · Skenario

- **A.** Watering hole
- **B.** Direct physical access
- **C.** Removable media
- **D.** Supply chain

10. Users who mistype `examp1e.com` for `example.com` are redirected to a site that harvests credentials. Which technique is this?

Objektif 2.2 · Skenario

- **A.** DNS tunneling
- **B.** Typosquatting
- **C.** Watering hole
- **D.** Domain fronting

11. Security researchers learn that a website frequently visited by employees of a defense contractor was compromised to serve exploit code only to visitors from that contractor's IP range. Which attack is this?

Objektif 2.2 · Skenario

- **A.** Pretexting
- **B.** Whaling
- **C.** Spear phishing
- **D.** Watering hole

12. An attacker spoofs the CEO's email address and asks the finance director to urgently wire funds to a new supplier account. Which attack is this?

Objektif 2.2 · Skenario

- **A.** Vishing
- **B.** Pharming
- **C.** Whaling
- **D.** Business email compromise

13. Customers receive a text message claiming their parcel is held at customs, with a link to a credential-harvesting page. Which vector is used?

Objektif 2.2 · Skenario

- **A.** Smishing
- **B.** Phishing
- **C.** Pretexting
- **D.** Vishing

14. An attacker calls the help desk, claims to be a new employee locked out of the VPN, and asks the agent to reset the MFA token. Which technique is this?

Objektif 2.2 · Skenario

- **A.** Vishing and pretexting
- **B.** Shoulder surfing
- **C.** Credential harvesting
- **D.** Tailgating

15. An employee finds a USB drive labeled "Payroll 2025" in the parking lot and plugs it into a workstation. Which threat vector is demonstrated?

Objektif 2.2 · Skenario

- **A.** Unsupported system
- **B.** Removable media
- **C.** Supply chain
- **D.** Open service port

16. A database server is reachable from the internet on port 3389 with the default administrator password unchanged. Which two threat vectors are combined?

Objektif 2.2 · Skenario

- **A.** Open service port and default credentials
- **B.** Removable media and unpatched software
- **C.** Wireless and Bluetooth
- **D.** Shadow IT and insider threat

17. A production server still runs an operating system that no longer receives security updates. Which term and risk BEST apply?

Objektif 2.2 · Skenario

- **A.** Shadow IT; the system is unsupported by IT
- **B.** Zero-day; unknown vulnerability with no patch
- **C.** End-of-life system; known vulnerabilities will never be patched
- **D.** Legacy protocol; encryption is weaker

18. An attacker within Bluetooth range connects to an unpaired headset and extracts contact data. Which wireless attack vector is this?

Objektif 2.2 · Skenario

- **A.** Bluejacking
- **B.** Bluesnarfing
- **C.** Deauthentication
- **D.** Evil twin

19. An employee downloads an invoice document from a supplier's website and opens it. The document contains a macro that downloads a payload when the user clicks "Enable Content". Which threat vector is this?

Objektif 2.2 · Skenario

- **A.** Message-based
- **B.** Image-based
- **C.** Voice-based
- **D.** File-based

20. A software vendor's build server is compromised, and the attacker inserts malicious code into a signed update that customers install automatically. Which vector is used?

Objektif 2.2 · Skenario

- **A.** Watering hole
- **B.** Open service port
- **C.** Unsupported system
- **D.** Supply chain (software provider)

21. An attacker sends more input to a program than its fixed-size buffer can hold, overwriting the return address and executing shellcode. Which vulnerability is this?

Objektif 2.3 · Skenario

- **A.** SQL injection
- **B.** Race condition
- **C.** Buffer overflow
- **D.** Directory traversal

22. A web application checks whether a file exists and then opens it, but an attacker swaps the file with a symbolic link between the two operations. Which vulnerability class is this?

Objektif 2.3 · Skenario

- **A.** Privilege escalation
- **B.** Injection
- **C.** TOCTOU race condition
- **D.** Buffer overflow

23. A login form returns the error `You have an error in your SQL syntax near 'OR 1=1'`. Which vulnerability is MOST likely present?

Objektif 2.3 · Skenario

- **A.** Cross-site scripting
- **B.** SQL injection
- **C.** Cross-site request forgery
- **D.** Directory traversal

24. A comment field stores raw HTML, and a submitted `<script>` tag executes in every visitor's browser. Which vulnerability is this?

Objektif 2.3 · Skenario

- **A.** Stored XSS
- **B.** CSRF
- **C.** Clickjacking
- **D.** Reflected XSS

25. A user logged in to a banking site visits a malicious page that silently submits a fund-transfer request using the user's existing session cookie. Which attack is this?

Objektif 2.3 · Skenario

- **A.** CSRF
- **B.** Session fixation
- **C.** SQL injection
- **D.** XSS

26. A request for `https://shop.example.com/download?file=../../../../etc/passwd` returns the contents of the system password file. Which vulnerability is exploited?

Objektif 2.3 · Skenario

- **A.** XML external entity
- **B.** Directory traversal
- **C.** Command injection
- **D.** Insecure direct object reference

27. Malicious code running inside a guest VM exploits a hypervisor flaw to execute on the host. Which vulnerability is this?

Objektif 2.3 · Skenario

- **A.** Container breakout via misconfiguration
- **B.** Resource reuse
- **C.** VM escape
- **D.** VM sprawl

28. An organization has 400 virtual machines but only 180 are documented and patched. Many are unused but still running. Which risk is this?

Objektif 2.3 · Skenario

- **A.** Resource reuse
- **B.** Cross-site scripting
- **C.** VM escape
- **D.** VM sprawl

29. A developer stores backups in a cloud bucket and sets it to public-read for convenience. Which vulnerability is this?

Objektif 2.3 · Skenario

- **A.** Weak encryption
- **B.** Supply chain
- **C.** Zero-day
- **D.** Cloud misconfiguration

30. Which statement BEST describes a zero-day vulnerability?

Objektif 2.3 · Definisi

- **A.** A vulnerability unknown to the vendor, for which no patch exists
- **B.** A vulnerability in open-source software only
- **C.** A vulnerability exploited exactly once
- **D.** A vulnerability that has been patched but not yet deployed

31. An Android user enables installation of apps from unknown sources to get a free premium app, which then steals banking credentials. Which two risks are present?

Objektif 2.3 · Skenario

- **A.** Rooting and supply chain
- **B.** VM escape and sideloading
- **C.** Sideloading and malicious application
- **D.** Jailbreaking and bootkit

32. A router model has not received firmware updates for four years and has known remotely exploitable flaws. Which vulnerability category applies?

Objektif 2.3 · Skenario

- **A.** Application injection
- **B.** Cryptographic downgrade
- **C.** Mobile jailbreaking
- **D.** Hardware end-of-life and unpatched firmware

33. An application encrypts credit card numbers with a hard-coded AES key stored in the source repository. Which weakness is this?

Objektif 2.3 · Skenario

- **A.** Certificate expiration
- **B.** Improper key storage
- **C.** Weak cipher algorithm choice
- **D.** Insufficient hashing rounds

34. Malicious code is injected into a running process by forcing it to load an attacker-controlled library. Which technique is this?

Objektif 2.3 · Skenario

- **A.** Buffer overflow
- **B.** Logic bomb
- **C.** Privilege escalation
- **D.** DLL injection

35. An old virtual machine is deleted and its disk reallocated to a new tenant, who is able to recover fragments of the previous tenant's data. Which risk applies?

Objektif 2.3 · Skenario

- **A.** Resource reuse
- **B.** VM sprawl
- **C.** Data sovereignty
- **D.** VM escape

36. A network switch received from a hardware supplier contains an undocumented cellular modem that beacons out. Which vulnerability category is this?

Objektif 2.3 · Skenario

- **A.** Firmware downgrade
- **B.** Misconfiguration
- **C.** Zero-day
- **D.** Supply chain (hardware provider)

37. Users report that files on a shared drive have been renamed with a `.locked` extension and a text file demands cryptocurrency. Which malware type is this?

Objektif 2.4 · Skenario

- **A.** Rootkit
- **B.** Spyware
- **C.** Worm
- **D.** Ransomware

38. Malware spreads to every host on a network within minutes without any user interaction, exploiting a single unpatched SMB flaw. Which malware type is this?

Objektif 2.4 · Skenario

- **A.** Worm
- **B.** Virus
- **C.** Logic bomb
- **D.** Trojan

39. A compromised host shows no signs of malware in Task Manager, yet attackers retain administrative access across reboots. Which malware type is MOST likely?

Objektif 2.4 · Skenario

- **A.** Adware
- **B.** Ransomware
- **C.** Keylogger
- **D.** Rootkit

40. A workstation periodically sends keystrokes and clipboard contents to an external IP address. Which malware behavior is this?

Objektif 2.4 · Skenario

- **A.** Ransomware
- **B.** Logic bomb
- **C.** Keylogger
- **D.** Cryptominer

41. A terminated employee's script deletes all HR records when it detects that his account has been disabled. Which malware type is this?

Objektif 2.4 · Skenario

- **A.** Backdoor
- **B.** Trojan
- **C.** Logic bomb
- **D.** Worm

42. Multiple internal hosts beacon to the same external IP every 60 seconds using HTTPS, and that IP is a known command-and-control server. Which malware infrastructure is present?

Objektif 2.4 · Skenario

- **A.** Sinkhole
- **B.** Proxy chain
- **C.** Botnet
- **D.** Honeypot

43. A server's CPU usage jumps to 100 percent and the security team finds a process mining cryptocurrency. Which malware category applies?

Objektif 2.4 · Skenario

- **A.** Ransomware
- **B.** Rootkit
- **C.** Spyware
- **D.** Cryptomalware

44. An investigation finds no malicious executable on disk, but a PowerShell process loaded a script directly into memory and established outbound connections. Which malware characteristic is this?

Objektif 2.4 · Skenario

- **A.** Polymorphic malware
- **B.** Armored virus
- **C.** Multipartite virus
- **D.** Fileless malware

45. A wireless survey finds two access points with the same SSID, but one has a stronger signal and a different BSSID near the lobby. Which attack is MOST likely?

Objektif 2.4 · Skenario

- **A.** Deauthentication
- **B.** WPS brute force
- **C.** MAC flooding
- **D.** Evil twin

46. Wireless clients are repeatedly disconnected and forced to reconnect to an attacker's access point. Which attack is being used?

Objektif 2.4 · Skenario

- **A.** DNS poisoning
- **B.** VLAN hopping
- **C.** Deauthentication attack
- **D.** ARP poisoning

47. An attacker on the same LAN sends forged ARP replies so that traffic destined for the gateway goes through the attacker's machine. Which attack is this?

Objektif 2.4 · Skenario

- **A.** On-path attack via BGP hijack
- **B.** ARP poisoning
- **C.** DNS poisoning
- **D.** MAC flooding

48. Users typing `www.bank.com` are directed to an attacker's IP address because a compromised DNS record was modified. Which attack is this?

Objektif 2.4 · Skenario

- **A.** ARP poisoning
- **B.** Typosquatting
- **C.** Domain fronting
- **D.** DNS poisoning

49. An attacker configures a switch port as a trunk and gains access to traffic from multiple VLANs. Which attack is this?

Objektif 2.4 · Skenario

- **A.** MAC flooding
- **B.** ARP poisoning
- **C.** DNS tunneling
- **D.** VLAN hopping

50. An attacker floods a switch with thousands of fake MAC addresses until it starts broadcasting all frames to every port. Which attack is this?

Objektif 2.4 · Skenario

- **A.** ARP poisoning
- **B.** VLAN hopping
- **C.** MAC flooding
- **D.** MAC cloning

51. A user connects to a hotel Wi-Fi and later discovers the captive portal was operated by an attacker who intercepted all traffic. Which attack occurred?

Objektif 2.4 · Skenario

- **A.** On-path attack
- **B.** SQL injection
- **C.** DDoS
- **D.** Privilege escalation

52. An attacker captures a valid authentication token and resends it later to gain access. Which attack is this?

Objektif 2.4 · Skenario

- **A.** Brute force
- **B.** Session fixation
- **C.** Replay attack
- **D.** Pass-the-hash

53. A web service is overwhelmed by traffic from a large botnet, exhausting bandwidth so that legitimate users cannot connect. Which attack type is this?

Objektif 2.4 · Skenario

- **A.** Application-layer DoS
- **B.** SYN flood only
- **C.** Smurf attack
- **D.** Volumetric DDoS

54. An attacker tries the password `Spring2025!` against 500 different accounts, staying under the lockout threshold for each account. Which attack is this?

Objektif 2.4 · Skenario

- **A.** Credential stuffing
- **B.** Dictionary attack
- **C.** Rainbow table attack
- **D.** Password spraying

55. Attackers use a list of username/password pairs leaked from another company to log in to your service, succeeding on accounts where users reused passwords. Which attack is this?

Objektif 2.4 · Skenario

- **A.** Pass-the-hash
- **B.** Credential stuffing
- **C.** Password spraying
- **D.** Brute force

56. An attacker steals a password hash database and uses precomputed tables to recover common passwords quickly. Which attack and mitigation pair is CORRECT?

Objektif 2.4 · Skenario

- **A.** Rainbow table; salting passwords
- **B.** Brute force; longer passwords
- **C.** Password spraying; account lockout
- **D.** Dictionary attack; MFA

57. Web server logs show requests containing `' UNION SELECT username, password FROM users--`. Which attack is occurring?

Objektif 2.4 · Skenario

- **A.** Command injection
- **B.** SQL injection
- **C.** Cross-site scripting
- **D.** Directory traversal

58. A user account successfully authenticates from Jakarta and, 20 minutes later, from Frankfurt. Which indicator is this?

Objektif 2.4 · Skenario

- **A.** Account lockout
- **B.** Resource consumption
- **C.** Impossible travel
- **D.** Concurrent session usage

59. A single user account shows five active VPN sessions from different countries at the same time. Which indicator is present?

Objektif 2.4 · Skenario

- **A.** Missing logs
- **B.** Concurrent session usage
- **C.** Impossible travel
- **D.** Account lockout

60. An account is locked after 40 failed logins in two minutes, followed by a help desk call from someone claiming to be the user. Which attack might this indicate?

Objektif 2.4 · Skenario

- **A.** Ransomware
- **B.** DNS poisoning
- **C.** Logic bomb
- **D.** Brute force or targeted lockout, possibly social engineering follow-up

61. A SIEM alert shows a sudden spike in outbound traffic from a database server to an unknown external IP at 3 a.m., while the server's normal traffic is internal only. Which indicator is this?

Objektif 2.4 · Skenario

- **A.** Account lockout
- **B.** Blocked content
- **C.** Missing logs
- **D.** Resource consumption and unusual data flow

62. An administrator notices that firewall logs for a specific 30-minute window are absent, although the firewall remained online. Which indicator should be investigated?

Objektif 2.4 · Skenario

- **A.** Missing logs, possibly indicating tampering
- **B.** Out-of-cycle logging
- **C.** Account lockout
- **D.** Blocked content

63. An organization discovers screenshots of its internal documents posted on a public paste site, along with a claim of stolen data. Which indicator category is this?

Objektif 2.4 · Skenario

- **A.** Concurrent session
- **B.** Resource inaccessibility
- **C.** Published or documented data
- **D.** Out-of-cycle logging

64. A legacy manufacturing system cannot be patched. The team places it in its own VLAN with a firewall that permits only one needed protocol to one server. Which mitigation is this?

Objektif 2.5 · Skenario

- **A.** Segmentation
- **B.** Isolation
- **C.** Decommissioning
- **D.** Patching

65. An organization allows only approved executables to run on endpoints; all others are blocked by hash. Which mitigation is this?

Objektif 2.5 · Skenario

- **A.** EDR quarantine
- **B.** Application allow list
- **C.** Application block list
- **D.** Host-based firewall

66. Before a laptop is granted network access, the switch port checks its patch level and antivirus status through an agent. Which technology is this?

Objektif 2.5 · Skenario

- **A.** NAC
- **B.** DLP
- **C.** MDM
- **D.** SIEM

67. A security team wants to detect and automatically respond to malicious behavior such as process injection on endpoints, with the ability to isolate a host. Which tool is MOST appropriate?

Objektif 2.5 · Skenario

- **A.** Antivirus signature scanner
- **B.** NetFlow analyzer
- **C.** HIDS
- **D.** EDR

68. A company must prevent employees from emailing unencrypted customer ID numbers to personal accounts. Which control is MOST appropriate?

Objektif 2.5 · Skenario

- **A.** Full-disk encryption
- **B.** DLP
- **C.** NAC
- **D.** WAF

69. A suspicious email attachment must be detonated to observe its behavior before release. Which mitigation technique is used?

Objektif 2.5 · Skenario

- **A.** Honeypot
- **B.** Tokenization
- **C.** Sandboxing
- **D.** Quarantine

70. A new server is deployed from a hardened image that disables unnecessary services, enforces password rules, and configures logging. Which concept is this?

Objektif 2.5 · Skenario

- **A.** Secure baseline
- **B.** Change management
- **C.** Least privilege
- **D.** Network segmentation

71. A server reaches end of life and is removed from the network, its disks are wiped, and its DNS records are deleted. Which mitigation is being performed?

Objektif 2.5 · Skenario

- **A.** Segmentation
- **B.** Decommissioning
- **C.** Patching
- **D.** Isolation

72. A company must support personal phones for email while enforcing encryption and remote wipe on those devices. Which solution is MOST appropriate?

Objektif 2.5 · Skenario

- **A.** MDM with BYOD policy
- **B.** NAC
- **C.** DLP
- **D.** VDI only

73. An administrator wants to block lateral SMB traffic between workstations while allowing it to the file server only. Which control is MOST efficient?

Objektif 2.5 · Skenario

- **A.** DLP
- **B.** Full-disk encryption
- **C.** Host-based firewall rules
- **D.** Application allow list

74. Sensitive cryptographic keys must be processed inside a CPU-protected area isolated from the main operating system. Which technology is this?

Objektif 2.5 · Skenario

- **A.** HSM
- **B.** Vault
- **C.** Secure enclave
- **D.** TPM

Domain 3 — Security Architecture (18%)

48 soal · objektif: 3.1, 3.2, 3.3, 3.4

1. A company moves its email service to a SaaS provider. Under the shared responsibility model, which task remains the CUSTOMER's responsibility?

Objektif 3.1 · Skenario

- **A.** Patching the email application servers
- **B.** Managing user accounts, access, and data classification
- **C.** Securing the physical data center
- **D.** Maintaining the hypervisor

2. A team deploys virtual machines in IaaS. Which security task is the CUSTOMER responsible for?

Objektif 3.1 · Skenario

- **A.** Physical security of the data center
- **B.** Patching the guest operating system and configuring security groups
- **C.** Maintaining the storage firmware
- **D.** Securing the network backbone

3. A development team uses a platform where the provider manages the runtime and OS, while the team only uploads code and configures environment variables. Which service model is this?

Objektif 3.1 · Skenario

- **A.** On-premises
- **B.** IaaS
- **C.** PaaS
- **D.** SaaS

4. A company runs sensitive workloads in its own data center but uses a public cloud for seasonal capacity. Which architecture is this?

Objektif 3.1 · Skenario

- **A.** Community cloud
- **B.** Private cloud
- **C.** Multi-cloud
- **D.** Hybrid cloud

5. An organization defines its cloud network entirely in Terraform templates stored in Git, and changes are applied through a pipeline. Which concept is this?

Objektif 3.1 · Skenario

- **A.** Microservices
- **B.** Software-defined perimeter
- **C.** Infrastructure as code
- **D.** Serverless computing

6. A company runs short-lived functions that execute only when an event occurs, with no server to patch. Which security consideration is MOST important?

Objektif 3.1 · Skenario

- **A.** Function-level permissions and secrets management
- **B.** Hardening the hypervisor
- **C.** Managing disk encryption keys
- **D.** Patching the underlying operating system

7. An application is split into small independent services that communicate over APIs and are deployed separately. Which architecture is this?

Objektif 3.1 · Skenario

- **A.** Mainframe
- **B.** Client-server
- **C.** Monolithic
- **D.** Microservices

8. Two containers on the same host are compromised through a kernel vulnerability, allowing the attacker to affect the other container. Which architectural weakness does this illustrate?

Objektif 3.1 · Skenario

- **A.** Containers share the host kernel
- **B.** Containers do not support encryption
- **C.** Containers cannot use network policies
- **D.** Containers require a hypervisor for isolation

9. A hospital's infusion pumps run an embedded real-time operating system that must respond within milliseconds. Which security constraint is MOST significant?

Objektif 3.1 · Skenario

- **A.** The devices do not support Wi-Fi
- **B.** The devices store no data
- **C.** The devices cannot tolerate standard patching downtime or latency-heavy controls
- **D.** The devices use outdated web browsers

10. A power plant uses SCADA to control physical equipment. Which security objective is prioritized above confidentiality in this environment?

Objektif 3.1 · Skenario

- **A.** Non-repudiation
- **B.** Data minimization
- **C.** Anonymity
- **D.** Availability and safety

11. A 5G deployment uses network slicing to give emergency services guaranteed bandwidth separate from consumer traffic. Which security benefit does network slicing provide?

Objektif 3.1 · Skenario

- **A.** Automatic encryption of all application data
- **B.** Elimination of the need for authentication
- **C.** Replacement for endpoint detection
- **D.** Isolation between logical networks with distinct policies

12. A company wants to centralize routing decisions in a controller while switches forward traffic based on those decisions. Which architecture is described?

Objektif 3.1 · Skenario

- **A.** Virtual private network
- **B.** Network access control
- **C.** Spanning tree protocol
- **D.** Software-defined networking

13. A firewall is configured to allow all traffic if its rule engine crashes, to avoid business interruption. Which failure mode is this, and what is the risk?

Objektif 3.2 · Skenario

- **A.** Fail-over; traffic goes to a standby device
- **B.** Fail-closed; traffic is blocked until fixed
- **C.** Fail-open; all traffic is allowed during failure
- **D.** Fail-safe; traffic is inspected twice

14. An IDS is connected to a mirrored switch port and only receives copies of traffic, so it cannot block an attack. Which deployment characteristic is this?

Objektif 3.2 · Skenario

- **A.** Transparent proxy
- **B.** Inline
- **C.** Passive (tap/SPAN)
- **D.** Fail-closed

15. A security team must inspect encrypted HTTPS traffic for data leaks. Which capability is required?

Objektif 3.2 · Skenario

- **A.** Port mirroring only
- **B.** NetFlow sampling
- **C.** TLS inspection with a trusted internal CA
- **D.** DNSSEC validation

16. Which device provides application-layer protection against SQL injection and cross-site scripting for a public web application?

Objektif 3.2 · Skenario

- **A.** Load balancer
- **B.** Router with ACL
- **C.** Layer 4 firewall
- **D.** WAF

17. A company replaces separate firewall, IPS, and antivirus gateway appliances with a single device that combines these functions. Which term BEST describes it?

Objektif 3.2 · Skenario

- **A.** HIDS
- **B.** UTM
- **C.** WAF
- **D.** Reverse proxy

18. Remote workers must access internal applications without exposing them directly to the internet, and access should be granted per application after device and identity checks. Which solution is BEST?

Objektif 3.2 · Skenario

- **A.** Traditional site-to-site VPN
- **B.** ZTNA
- **C.** Port forwarding on the firewall
- **D.** RDP gateway with MFA only

19. An organization wants to connect two branch offices over the internet with encrypted traffic at the network layer, supporting multiple protocols. Which technology is MOST appropriate?

Objektif 3.2 · Skenario

A. IPsec VPN
B. SSH tunnel per user
C. DNSSEC
D. TLS on each application

20. A cloud-first company wants to combine network and security functions (SWG, CASB, firewall, ZTNA) delivered as a service at the edge. Which architecture is this?

Objektif 3.2 · Skenario

A. SASE
B. SD-WAN only
C. DMZ
D. VDI

21. Administrators must manage servers without exposing SSH to the internet. Which architecture is MOST appropriate?

Objektif 3.2 · Skenario

A. Public RDP with IP allow list
B. Jump host/bastion in a management subnet with MFA
C. Direct SSH with password authentication
D. Port knocking only

22. A security architect must place a public web server so that it can be reached from the internet but cannot initiate connections to the internal database subnet. Which design is BEST?

Objektif 3.2 · Skenario

A. Put the web server on the internal LAN with a host firewall
B. Put the database in the DMZ with the web server
C. Use NAT to hide the web server
D. Put the web server in a DMZ with rules allowing only required outbound flows

23. An organization needs to monitor all traffic between two internal segments without affecting latency or risking a single point of failure. Which deployment is MOST appropriate?

Objektif 3.2 · Skenario

A. Host-based firewall
B. Inline IPS
C. Passive sensor on a TAP
D. Transparent proxy

24. Which statement about agent-based versus agentless security monitoring is CORRECT?

Objektif 3.2 · Perbandingan

A. Agent-based cannot detect file changes
B. Agentless requires kernel drivers on every host
C. Agent-based collects detailed host telemetry but requires software on each endpoint; agentless relies on network or API data
D. Agentless provides better endpoint process visibility than agent-based

25. Which data classification label typically requires the HIGHEST level of protection?

Objektif 3.3 · Definisi

- **A.** Confidential
- **B.** Sensitive
- **C.** Extremely sensitive
- **D.** Public

26. A company must ensure that customer data stored in a cloud region in Germany does not leave the EU. Which concept applies?

Objektif 3.3 · Skenario

- **A.** Data minimization
- **B.** Data masking
- **C.** Data retention
- **D.** Data sovereignty

27. A support portal shows only the last four digits of a customer's card number. Which technique is this?

Objektif 3.3 · Skenario

- **A.** Tokenization
- **B.** Data masking
- **C.** Hashing
- **D.** Anonymization

28. A payment processor replaces card numbers with random tokens, keeping the mapping in a secure vault. Which benefit is PRIMARY?

Objektif 3.3 · Skenario

- **A.** The token has no value if stolen, reducing PCI scope
- **B.** The token can be reversed by anyone
- **C.** The token shortens the card number for storage
- **D.** The token encrypts the entire database

29. A research dataset must remain usable for analytics but cannot identify individuals even if combined with other datasets. Which technique is MOST appropriate?

Objektif 3.3 · Skenario

- **A.** Anonymization
- **B.** Encryption
- **C.** Tokenization
- **D.** Salting

30. A company keeps customer records indefinitely "just in case". Which policy gap is MOST significant?

Objektif 3.3 · Skenario

- **A.** No MFA
- **B.** No data retention and destruction policy
- **C.** No encryption at rest
- **D.** No DLP

31. Which method is BEST for destroying data on a failed SSD before disposal?

Objektif 3.3 · Skenario

- **A.** Quick format
- **B.** Delete the partition
- **C.** Overwrite with zeros using software
- **D.** Physical destruction (shredding) or crypto-erase

32. A company wants to prevent sensitive files from being uploaded to personal cloud storage while allowing approved services. Which control is MOST appropriate?

Objektif 3.3 · Skenario

- **A.** SIEM
- **B.** CASB
- **C.** NAC
- **D.** WAF

33. Which data state is protected by TLS while data moves between a browser and a web server?

Objektif 3.3 · Definisi

- **A.** Data at rest
- **B.** Data in transit
- **C.** Data in use
- **D.** Data at rest and in use

34. A company collects only the customer's email address for a newsletter, even though it could collect birth date and phone number. Which principle is applied?

Objektif 3.3 · Skenario

- **A.** Data retention
- **B.** Non-repudiation
- **C.** Data minimization
- **D.** Data sovereignty

35. A system must tolerate the failure of one entire data center with no data loss and near-zero downtime. Which solution is MOST appropriate?

Objektif 3.4 · Skenario

- **A.** Active-active clustering across geographically dispersed sites
- **B.** Cold site with tape restore
- **C.** Single site with RAID 5
- **D.** Warm site with nightly backups

36. Which metric represents the maximum acceptable amount of data loss measured in time?

Objektif 3.4 · Definisi

- **A.** RTO
- **B.** RPO
- **C.** MTTR
- **D.** MTBF

37. A company requires a recovery site that is fully equipped with hardware and data replicated continuously, ready to take over within minutes. Which site type is this?

Objektif 3.4 · Skenario

- **A.** Cold site
- **B.** Warm site
- **C.** Hot site
- **D.** Reciprocal site

38. A team runs an exercise where participants discuss their response to a simulated ransomware scenario without actually invoking systems. Which test is this?

Objektif 3.4 · Skenario

- **A.** Penetration test
- **B.** Tabletop exercise
- **C.** Failover test
- **D.** Parallel processing test

39. Which backup strategy follows the 3-2-1 rule?

Objektif 3.4 · Skenario

- **A.** Three backups per day, two servers, one cloud
- **B.** Three administrators, two approvals, one change window
- **C.** Three sites, two ISPs, one firewall
- **D.** Three copies, on two different media, with one copy offsite

40. A company wants to avoid dependence on a single cloud provider's availability zone or proprietary services. Which strategies apply?

Objektif 3.4 · Skenario

- **A.** Data masking and tokenization
- **B.** Load balancing and caching
- **C.** Patching and hardening
- **D.** Geographic dispersion and platform diversity

41. A UPS provides 15 minutes of runtime, and a generator starts automatically after 10 seconds. Which risk remains if the generator fails to start?

Objektif 3.4 · Skenario

- **A.** Increased bandwidth consumption
- **B.** Certificate expiration
- **C.** Extended outage once the UPS battery is depleted
- **D.** Data corruption from too much power

42. A load balancer distributes traffic to three web servers, but session data is stored locally on each server, causing users to be logged out randomly. Which solution is MOST appropriate?

Objektif 3.4 · Skenario

- **A.** Enable RAID on the load balancer
- **B.** Add a second load balancer
- **C.** Sticky sessions or shared session store
- **D.** Increase the number of servers

43. A company must ensure a database can be restored to any point in time within the last 24 hours after accidental deletion. Which capability is required?

Objektif 3.4 · Skenario

- **A.** Continuous transaction log backups (point-in-time recovery)
- **B.** RAID 6
- **C.** Snapshot once per month
- **D.** Full backups once per week

44. A system has an MTBF of 2,000 hours and an MTTR of 4 hours. What is its approximate availability?

Objektif 3.4 · Perhitungan

- **A.** 95.0%
- **B.** 99.8%
- **C.** 99.2%
- **D.** 98.0%

45. During a failover test, the team switches traffic to the secondary site while keeping the primary running, then compares results. Which test type is this?

Objektif 3.4 · Skenario

- **A.** Simulation
- **B.** Cold-site activation
- **C.** Parallel processing
- **D.** Tabletop

46. A company stores backups on the same SAN as production to simplify recovery. Which principle is violated?

Objektif 3.4 · Skenario

- **A.** Data minimization
- **B.** Separation of duties
- **C.** Geographic separation and offline copy (3-2-1)
- **D.** Least privilege

47. An organization wants to reduce the attack surface of its public API by exposing only required endpoints and validating input at the gateway. Which architecture is MOST appropriate?

Objektif 3.1 · Skenario

- **A.** API gateway with schema validation, rate limiting, and authentication
- **B.** Direct exposure of each microservice
- **C.** VPN for every customer
- **D.** WAF in monitor-only mode

48. A network architect needs to enforce that only domain-joined, patched devices can reach the finance VLAN, regardless of user credentials. Which combination is MOST appropriate?

Objektif 3.2 · Skenario

- **A.** Captive portal with email registration
- **B.** 802.1X with NAC posture assessment and VLAN assignment
- **C.** WPA2-PSK with a shared password
- **D.** MAC address allow list only

Domain 4 — Security Operations (28%)

78 soal · objektif: 4.1, 4.2, 4.3, 4.4, 4.5, 4.6, 4.7, 4.8, 4.9

1. A new Linux server is deployed with only the required packages, SSH key-only authentication, and a host firewall. Which activity does this describe?

Objektif 4.1 · Skenario

- **A.** Hardening
- **B.** Patching
- **C.** Segmentation
- **D.** Decommissioning

2. A wireless network must authenticate each user individually and support certificate-based authentication without a shared key. Which configuration is BEST?

Objektif 4.1 · Skenario

- **A.** WPA2-PSK with a strong passphrase
- **B.** WPA3-Enterprise with 802.1X/EAP
- **C.** WEP with MAC filtering
- **D.** Open network with captive portal

3. A company issues smartphones to field staff and requires full device encryption, a PIN, and remote wipe, while separating corporate data from personal data. Which solution is MOST appropriate?

Objektif 4.1 · Skenario

- **A.** MDM with containerization/MAM
- **B.** NAC
- **C.** DLP only
- **D.** VPN only

4. Which risk is created by allowing users to sideload applications on corporate mobile devices?

Objektif 4.1 · Skenario

- **A.** Apps from untrusted sources may contain malware and bypass store review
- **B.** The device battery drains faster
- **C.** The device cannot connect to Wi-Fi
- **D.** The device loses its IMEI

5. A company wants to let contractors use their own laptops but requires that corporate applications run in an isolated environment. Which approach is BEST?

Objektif 4.1 · Skenario

- **A.** Full disk encryption on personal laptops
- **B.** Dual-boot with a corporate OS
- **C.** Local admin rights for contractors
- **D.** VDI or application virtualization

6. Which action BEST reduces the attack surface of a web server?

Objektif 4.1 · Skenario

- **A.** Install additional monitoring agents
- **B.** Increase CPU and RAM
- **C.** Enable directory listing for troubleshooting
- **D.** Disable unused modules and services, remove sample applications

7. A workstation is configured to block execution of any binary not signed by the company's certificate authority. Which control is this?

Objektif 4.1 · Skenario

- **A.** Host-based IDS
- **B.** Full-disk encryption
- **C.** DLP
- **D.** Application allow listing

8. A company must ensure that a decommissioned laptop's drive cannot be read even if the platters are removed. Which method is BEST?

Objektif 4.1 · Skenario

- **A.** Deleting the user profile
- **B.** Quick format
- **C.** Physical destruction (shredding)
- **D.** Moving files to the recycle bin

9. A security team cannot determine which servers are missing patches because there is no authoritative list of deployed systems. Which process is missing?

Objektif 4.2 · Skenario

- **A.** Asset inventory and discovery
- **B.** Incident response
- **C.** Change management
- **D.** Data loss prevention

10. Which document BEST tracks who is responsible for a laptop throughout its lifecycle?

Objektif 4.2 · Skenario

- **A.** Network diagram
- **B.** Incident log
- **C.** Firewall rule set
- **D.** Asset tag with assignment records

11. Before disposing of a multifunction printer, which step is MOST important?

Objektif 4.2 · Skenario

- **A.** Update the firmware
- **B.** Change the admin password
- **C.** Sanitize or destroy the internal storage that may contain scanned documents
- **D.** Remove the paper tray

12. Which term describes verifying that a storage device has been properly sanitized before reuse or disposal?

Objektif 4.2 · Definisi

- **A.** Certification of sanitization
- **B.** Chain of custody
- **C.** Asset tagging
- **D.** Baseline comparison

13. A vulnerability scan reports a critical flaw on a server, but the security analyst confirms the affected service is disabled. What should the analyst do?

Objektif 4.3 · Skenario

- **A.** Mark it as a false positive with justification and evidence
- **B.** Patch the server immediately during business hours
- **C.** Ignore all future scans from that scanner
- **D.** Escalate it as an active incident

14. Which CVSS metric group reflects the characteristics of the vulnerability that change over time, such as exploit maturity?

Objektif 4.3 · Skenario

- **A.** Impact score
- **B.** Base score
- **C.** Temporal score
- **D.** Environmental score

15. A scanner reports 400 vulnerabilities, but only 12 affect internet-facing systems with known exploits. Which approach BEST prioritizes remediation?

Objektif 4.3 · Skenario

- **A.** Patch all 400 simultaneously
- **B.** Ignore all low-severity findings permanently
- **C.** Fix in CVSS score order regardless of exposure
- **D.** Prioritize by exploitability, exposure, and business impact

16. A critical vulnerability cannot be patched for 60 days due to vendor constraints. Which response is MOST appropriate?

Objektif 4.3 · Skenario

- **A.** Hide the finding from the report
- **B.** Disable the vulnerability scanner
- **C.** Immediately decommission the system without a plan
- **D.** Request a documented exception with compensating controls and review date

17. After applying a patch, which activity BEST validates that the vulnerability is actually remediated?

Objektif 4.3 · Skenario

- **A.** Review the change ticket
- **B.** Rescan the host and verify the finding no longer appears
- **C.** Ask the vendor whether the patch works
- **D.** Check that the server reboots

18. A researcher discovers a vulnerability and privately notifies the vendor, agreeing to withhold details until a patch is released. Which practice is this?

Objektif 4.3 · Skenario

- **A.** Bug bounty
- **B.** Penetration testing
- **C.** Threat hunting
- **D.** Responsible disclosure

19. A penetration test is authorized in writing with defined scope, time window, and emergency contacts. Which document governs this?

Objektif 4.3 · Skenario

- **A.** Incident response plan
- **B.** Rules of engagement
- **C.** Service level agreement
- **D.** Acceptable use policy

20. Which scan configuration is MOST likely to find missing patches and insecure settings on a server?

Objektif 4.3 · Skenario

- **A.** Unauthenticated external scan
- **B.** Credentialed internal scan
- **C.** Ping sweep only
- **D.** Port scan only

21. A company wants to continuously identify vulnerabilities in container images before deployment. Which practice is BEST?

Objektif 4.3 · Skenario

- **A.** Rely on the base image being official
- **B.** Disable the registry scanner to speed builds
- **C.** Scan images in the CI/CD pipeline and block builds with critical findings
- **D.** Scan production once a year

22. Which tool aggregates logs from firewalls, servers, and applications, correlates events, and generates alerts?

Objektif 4.4 · Skenario

- **A.** NetFlow collector
- **B.** WAF
- **C.** NAC
- **D.** SIEM

23. An analyst wants to automatically enrich alerts, create tickets, and block an IP without manual steps. Which technology is MOST appropriate?

Objektif 4.4 · Skenario

- **A.** SIEM only
- **B.** SOAR
- **C.** HIDS
- **D.** DLP

24. A network engineer needs summary metadata about which hosts communicate most, without capturing full packet contents. Which technology is BEST?

Objektif 4.4 · Skenario

- **A.** Syslog
- **B.** NetFlow
- **C.** Packet capture
- **D.** Honeypot

25. An alert fires for the same benign administrative script every morning, drowning out real alerts. Which action is MOST appropriate?

Objektif 4.4 · Skenario

- **A.** Tune the alert with an exception for that known-good behavior
- **B.** Disable the SIEM
- **C.** Ignore all alerts from that host
- **D.** Increase the alert threshold for every rule

26. Which data source is BEST for identifying a malicious process that ran only in memory on an endpoint?

Objektif 4.4 · Skenario

- **A.** DNS zone file
- **B.** EDR telemetry
- **C.** Firewall logs
- **D.** NetFlow records

27. A SOC wants to detect compromised hosts by analyzing DNS queries for domains associated with malware. Which tool is MOST appropriate?

Objektif 4.4 · Skenario

- **A.** DLP
- **B.** DNS filtering with threat intelligence feeds
- **C.** Full-disk encryption
- **D.** NAC

28. Which protocol should be used to collect device status and traps securely from network equipment?

Objektif 4.4 · Skenario

- **A.** Telnet
- **B.** TFTP
- **C.** SNMPv3
- **D.** SNMPv1

29. A file integrity monitoring tool alerts that `/etc/passwd` changed outside the change window. Which type of monitoring is this?

Objektif 4.4 · Skenario

- **A.** DLP
- **B.** NAC
- **C.** WAF
- **D.** FIM

30. A company wants to prevent users from visiting known phishing and malware domains at the DNS level. Which control is MOST appropriate?

Objektif 4.5 · Skenario

- **A.** DLP
- **B.** DNS filtering
- **C.** Host-based firewall
- **D.** Full-disk encryption

31. An organization wants to ensure that only authenticated and encrypted LDAP queries are allowed. Which configuration is required?

Objektif 4.5 · Skenario

- **A.** Kerberos on port 88 only
- **B.** RADIUS on port 1812
- **C.** LDAPS on port 636
- **D.** LDAP on port 389

32. Which email authentication mechanism allows a domain owner to specify which servers may send email on its behalf?

Objektif 4.5 · Skenario

- **A.** DKIM
- **B.** DMARC
- **C.** S/MIME
- **D.** SPF

33. A company wants to receive reports about emails that fail authentication and instruct receivers to reject them. Which record provides this?

Objektif 4.5 · Skenario

- **A.** DMARC record with p=reject and rua reporting
- **B.** SPF record with -all
- **C.** DKIM public key
- **D.** MX record

34. Which secure protocol should replace Telnet for remote administration of network devices?

Objektif 4.5 · Skenario

- **A.** SSH
- **B.** FTP
- **C.** HTTP
- **D.** SNMPv1

35. A SOC wants to detect anomalous user behavior such as accessing unusual volumes of data at odd hours. Which technology is MOST appropriate?

Objektif 4.5 · Skenario

- **A.** UEBA
- **B.** WAF
- **C.** NAC
- **D.** FIM

36. To reduce the risk of credential theft from memory, which Windows protection should be enabled?

Objektif 4.5 · Skenario

- **A.** Remote Registry
- **B.** SMBv1
- **C.** Credential Guard / LSASS protection
- **D.** AutoPlay

37. Which capability allows an organization to block USB mass storage on endpoints while still permitting keyboards and mice?

Objektif 4.5 · Skenario

- **A.** Full-disk encryption
- **B.** NAC
- **C.** DLP
- **D.** Endpoint device control policy

38. An employee left the company three weeks ago, but her account still authenticates and has access to email. Which IAM process failed?

Objektif 4.6 · Skenario

- **A.** Federation
- **B.** Attestation
- **C.** Deprovisioning
- **D.** Provisioning

39. After signing in once to a corporate identity provider, a user can access email, CRM, and the intranet without re-entering credentials. Which capability is this?

Objektif 4.6 · Skenario

- **A.** SSO
- **B.** MFA
- **C.** PAM
- **D.** RADIUS

40. Which statement correctly distinguishes SAML from OAuth?

Objektif 4.6 · Perbandingan

- **A.** OAuth authenticates users directly; SAML authorizes APIs
- **B.** SAML is an authentication/authorization federation standard using XML assertions; OAuth is an authorization framework for delegated access using tokens
- **C.** SAML is used for API authorization; OAuth is used for browser SSO only
- **D.** Both are password hashing algorithms

41. A user authenticates to Active Directory and receives a ticket-granting ticket used to request service tickets. Which protocol is this?

Objektif 4.6 · Skenario

- **A.** TACACS+
- **B.** LDAP
- **C.** Kerberos
- **D.** RADIUS

42. Which statement about RADIUS and TACACS+ is CORRECT?

Objektif 4.6 · Perbandingan

- **A.** RADIUS encrypts the entire packet; TACACS+ encrypts only the password
- **B.** Both use UDP and encrypt nothing
- **C.** TACACS+ is only for wireless authentication
- **D.** RADIUS typically uses UDP and encrypts only the password; TACACS+ uses TCP and encrypts the entire payload

43. An application must query user attributes and group membership from Active Directory over a standard protocol. Which protocol is used?

Objektif 4.6 · Skenario

- **A.** SMTP
- **B.** SNMP
- **C.** NTP
- **D.** LDAP

44. Access to a resource is determined by the resource owner who sets permissions for individual users. Which access control model is this?

Objektif 4.6 · Skenario

- **A.** DAC
- **B.** MAC
- **C.** RBAC
- **D.** ABAC

45. A defense contractor requires that access be based on clearance level and object classification labels, and users cannot change permissions. Which model is this?

Objektif 4.6 · Skenario

- **A.** Rule-based
- **B.** MAC
- **C.** DAC
- **D.** RBAC

46. A hospital grants nurses access based on their job function rather than individual permissions. Which model is this?

Objektif 4.6 · Skenario

- **A.** DAC
- **B.** ABAC
- **C.** MAC
- **D.** RBAC

47. An organization wants access decisions based on department, device compliance, time of day, and geolocation. Which model is MOST appropriate?

Objektif 4.6 · Skenario

- **A.** DAC
- **B.** MAC
- **C.** ABAC
- **D.** RBAC

48. A developer needs temporary admin access to production for two hours to troubleshoot an outage. Which practice is BEST?

Objektif 4.6 · Skenario

- **A.** Just-in-time elevation with approval and automatic revocation
- **B.** Grant permanent admin rights to avoid future delays
- **C.** Share the admin password with the team
- **D.** Disable MFA for the admin account

49. Which authentication method is considered phishing-resistant and passwordless?

Objektif 4.6 · Skenario

- **A.** Security questions
- **B.** Email magic link
- **C.** FIDO2 security key with passkeys
- **D.** SMS one-time code

50. A company wants to reduce the risk of credential stuffing against its web portal without changing the login experience for legitimate users. Which control is MOST appropriate?

Objektif 4.6 · Skenario

- **A.** Risk-based authentication with device fingerprint and impossible-travel checks
- **B.** Forcing password changes every 30 days
- **C.** Disabling account lockout
- **D.** Removing MFA to reduce friction

51. Which account type should be used by an application to run scheduled tasks, with permissions limited to only the required resources?

Objektif 4.6 · Skenario

- **A.** Personal account of the developer
- **B.** Guest account
- **C.** Service account with least privilege and managed credentials
- **D.** Shared administrator account

52. A manager reviews a report listing all users with access to the finance share and confirms each still needs it. Which process is this?

Objektif 4.6 · Skenario

- **A.** Provisioning
- **B.** Federation
- **C.** Password reset
- **D.** Access review/attestation

53. An organization must store administrative passwords in a vault, rotate them automatically, and record who checked them out. Which solution is this?

Objektif 4.6 · Skenario

- **A.** DLP
- **B.** PAM
- **C.** SSO
- **D.** MDM

54. A company wants new employees to receive accounts and group memberships automatically based on their HR role, and to have them removed automatically on termination. Which approach is BEST?

Objektif 4.6 · Skenario

- **A.** Annual cleanup only
- **B.** Automated provisioning/deprovisioning driven by HR (SCIM)
- **C.** Manual ticket for every account
- **D.** Shared department account

55. A cloud team wants to prevent developers from deploying storage buckets with public access, regardless of who runs the pipeline. Which control is BEST?

Objektif 4.7 · Skenario

- **A.** Manual review of every deployment
- **B.** Annual penetration test
- **C.** Security awareness training
- **D.** Guardrails/policy as code enforced in the pipeline

56. Which is a PRIMARY benefit of automating security operations with SOAR?

Objektif 4.7 · Skenario

- **A.** Removal of the need for human approval
- **B.** Faster, consistent response and reduced analyst toil
- **C.** Elimination of the need for logging
- **D.** Guaranteed prevention of all incidents

57. An automation script that disables compromised accounts fails silently when the HR API changes, and no one notices for a week. Which risk of automation is demonstrated?

Objektif 4.7 · Skenario

- **A.** Reduced efficiency
- **B.** Increased licensing cost
- **C.** Loss of audit trail
- **D.** Single point of failure and lack of monitoring

58. A CI/CD pipeline requires that secrets be fetched at runtime from a vault rather than stored in the repository. Which risk is being mitigated?

Objektif 4.7 · Skenario

- **A.** Certificate expiration
- **B.** Hard-coded credentials exposure
- **C.** Insufficient logging
- **D.** Network latency

59. Which sequence correctly represents the incident response lifecycle?

Objektif 4.8 · Definisi

- **A.** Preparation → Detection and analysis → Containment → Eradication → Recovery → Lessons learned
- **B.** Detection → Preparation → Recovery → Containment → Eradication
- **C.** Containment → Preparation → Detection → Recovery → Eradication
- **D.** Preparation → Eradication → Containment → Detection → Recovery

60. A workstation is confirmed infected with malware that may still be running. Investigators need volatile evidence. Which action should be taken FIRST?

Objektif 4.8 · Skenario

- **A.** Delete temporary files
- **B.** Isolate the host from the network but keep it powered on, then capture memory
- **C.** Immediately power off the host
- **D.** Reimage the host

61. After containing a ransomware outbreak, the team removes the malware, rebuilds encrypted servers, and restores data. Which phase follows next?

Objektif 4.8 · Skenario

- **A.** Recovery and validation, then lessons learned
- **B.** Preparation
- **C.** Detection
- **D.** Legal hold

62. During an investigation, a laptop is seized and each transfer is logged with signatures, dates, and storage location. Which concept is this?

Objektif 4.8 · Skenario

- **A.** Chain of custody
- **B.** Order of volatility
- **C.** Legal hold
- **D.** Root cause analysis

63. A legal department instructs IT to preserve all email and logs related to a lawsuit and to suspend automatic deletion. Which process is this?

Objektif 4.8 · Skenario

- **A.** Backup rotation
- **B.** Legal hold
- **C.** Data minimization
- **D.** Retention policy

64. After an incident, the team asks "why did the phishing email bypass the gateway and why was the user not trained?" Which activity is this?

Objektif 4.8 · Skenario

- **A.** Root cause analysis
- **B.** Tabletop exercise
- **C.** Vulnerability scan
- **D.** Threat hunting

65. A threat hunter forms a hypothesis that attackers are using signed binaries to evade detection, then searches telemetry for evidence. Which activity is this?

Objektif 4.8 · Skenario

- **A.** Compliance audit
- **B.** Threat hunting
- **C.** Vulnerability assessment
- **D.** Incident response

66. An analyst must determine which internal host initiated a connection to a known malicious IP at 02:14. Which log source is MOST directly useful?

Objektif 4.9 · Skenario

- **A.** Asset inventory
- **B.** Password policy document
- **C.** Firewall logs showing source IP, destination IP, and timestamp
- **D.** DNS zone file

67. Which tool is BEST for reconstructing an HTTP session and viewing the actual payload exchanged?

Objektif 4.9 · Skenario

- **A.** SIEM correlation only
- **B.** SNMP polling
- **C.** Protocol analyzer (packet capture)
- **D.** NetFlow

68. An investigator needs a timeline of user logons, process execution, and file changes on a Windows host. Which source provides the MOST complete evidence?

Objektif 4.9 · Skenario

- **A.** NetFlow only
- **B.** Antivirus scan report
- **C.** EDR telemetry combined with Windows event logs
- **D.** Firewall log only

69. Logs from servers are being overwritten after seven days, but an incident is discovered 30 days later. Which control should have been in place?

Objektif 4.9 · Skenario

- **A.** Disabling logging to save space
- **B.** Shorter backup windows
- **C.** Centralized log aggregation with retention/archiving
- **D.** Larger local disks

70. An analyst wants to compare the volume of outbound traffic per host over the last week to spot possible data exfiltration. Which data source is MOST appropriate?

Objektif 4.9 · Skenario

- **A.** NetFlow records
- **B.** Full packet captures
- **C.** Windows registry
- **D.** DHCP lease file

71. A ransomware incident is contained, but the team must decide whether to pay the ransom. Which factor is MOST important to consider first?

Objektif 4.8 · Skenario

- **A.** Whether tested, isolated backups can restore the data within RTO
- **B.** The attackers' reputation for returning data
- **C.** The cryptocurrency exchange rate
- **D.** The number of infected hosts

72. A company wants to block outbound traffic to known malicious IPs at the network edge while allowing all other outbound traffic. Which control is MOST appropriate?

Objektif 4.5 · Skenario

- **A.** DLP
- **B.** Full-disk encryption
- **C.** Egress filtering with threat intelligence blocklist
- **D.** Ingress filtering only

73. An organization wants to detect and block malicious PowerShell scripts that download and execute code. Which control combination is BEST?

Objektif 4.5 · Skenario

- **A.** Allowing only local administrators to use PowerShell
- **B.** Script block logging, constrained language mode, and EDR behavior detection
- **C.** Disabling Windows Update
- **D.** Increasing the PowerShell execution timeout

74. A penetration test finds that a low-privileged user can read the shadow file. Which category of finding is this?

Objektif 4.3 · Skenario

- **A.** Supply chain
- **B.** Privilege escalation
- **C.** Denial of service
- **D.** Cross-site scripting

75. Which wireless setting should be disabled because it allows attackers to brute-force the PIN and join the network?

Objektif 4.1 · Skenario

- **A.** WPA3
- **B.** 802.1X
- **C.** PMF
- **D.** WPS

76. An organization discovers an unauthorized server running in a lab closet, connected to the corporate network. Which control gap does this expose?

Objektif 4.2 · Skenario

- **A.** Missing full-disk encryption
- **B.** Insufficient email filtering
- **C.** Inadequate asset discovery and network access control
- **D.** Weak password policy

77. Which MFA factor category does a hardware token that generates a time-based code belong to?

Objektif 4.6 · Skenario

- **A.** Something you have
- **B.** Something you know
- **C.** Something you are
- **D.** Somewhere you are

78. During an incident, the team blocks the attacker's IP at the firewall, disables the compromised account, and segments the affected VLAN. Which IR phase is this?

Objektif 4.8 · Skenario

- **A.** Recovery
- **B.** Preparation
- **C.** Containment
- **D.** Eradication

Domain 5 — Security Program Management and Oversight (20%)

50 soal · objektif: 5.1, 5.2, 5.3, 5.4, 5.5, 5.6

1. Which statement BEST describes the difference between a policy and a procedure?

Objektif 5.1 · Perbandingan

- **A.** A policy applies only to executives; a procedure applies only to IT
- **B.** A policy is a high-level statement of management intent; a procedure is a detailed, step-by-step instruction
- **C.** A policy is optional guidance; a procedure is a legal requirement
- **D.** A policy describes technical settings; a procedure describes business goals

2. Which document defines what employees may and may not do with company computing resources?

Objektif 5.1 · Definisi

- **A.** Business partnership agreement
- **B.** Data retention policy
- **C.** Acceptable use policy
- **D.** Service level agreement

3. An organization must define how long financial records and email are kept and how they are destroyed afterward. Which policy is required?

Objektif 5.1 · Skenario

- **A.** Password policy
- **B.** Wireless policy
- **C.** Incident response policy
- **D.** Data retention policy

4. A security team documents who must approve firewall changes, what testing is required, and how to roll back. Which policy governs this?

Objektif 5.1 · Skenario

- **A.** Data classification policy
- **B.** Business continuity policy
- **C.** Change management policy
- **D.** Acceptable use policy

5. A company grants a temporary exception to allow an unsupported application for six months, with a documented risk owner and review date. Which governance element is this?

Objektif 5.1 · Skenario

- **A.** Guideline
- **B.** Baseline
- **C.** Policy exception
- **D.** Standard

6. Which group is typically responsible for approving security policies and accepting residual risk at the organizational level?

Objektif 5.1 · Skenario

- **A.** Help desk team
- **B.** External penetration tester
- **C.** Individual system administrators
- **D.** Governance/security steering committee

7. Which is an example of a standard rather than a policy?

Objektif 5.1 · Perbandingan

- **A.** "The company is committed to protecting customer data"
- **B.** "If a breach occurs, call the incident hotline"
- **C.** "Employees should consider using password managers"
- **D.** "All laptops must use AES-256 full-disk encryption"

8. After a merger, two companies have conflicting security requirements. Which approach BEST resolves the conflict?

Objektif 5.1 · Skenario

- **A.** Perform a gap analysis and update policies through the governance process
- **B.** Let each department keep its own rules indefinitely
- **C.** Apply the stricter rule only to the acquired company
- **D.** Suspend all security controls until integration finishes

9. Which metric BEST indicates whether security awareness training is changing behavior?

Objektif 5.1 · Skenario

- **A.** Number of training videos available
- **B.** Total training hours delivered
- **C.** Number of employees who completed onboarding
- **D.** Phishing simulation click rate trending downward over time

10. Which term describes the risk that remains after controls have been implemented?

Objektif 5.2 · Definisi

- **A.** Risk appetite
- **B.** Risk transfer
- **C.** Inherent risk
- **D.** Residual risk

11. An asset is valued at $200,000. A threat would destroy 25% of its value, and such an event is expected once every two years. What are the SLE and ALE?

Objektif 5.2 · Perhitungan

- **A.** SLE = $200,000; ALE = $100,000
- **B.** SLE = $50,000; ALE = $100,000
- **C.** SLE = $50,000; ALE = $25,000
- **D.** SLE = $25,000; ALE = $50,000

12. A company buys cyber insurance to cover the financial impact of a breach. Which risk response is this?

Objektif 5.2 · Skenario

- **A.** Transfer
- **B.** Avoid
- **C.** Mitigate
- **D.** Accept

13. A company stops offering a risky legacy service entirely rather than securing it. Which risk response is this?

Objektif 5.2 · Skenario

- **A.** Avoid
- **B.** Accept
- **C.** Transfer
- **D.** Mitigate

14. Management decides that a low-impact risk is acceptable because the cost of the control exceeds the potential loss. Which concept is applied?

Objektif 5.2 · Skenario

- **A.** Risk avoidance
- **B.** Risk transference
- **C.** Risk elimination
- **D.** Risk acceptance based on cost-benefit analysis

15. Which document records identified risks, owners, likelihood, impact, and treatment status?

Objektif 5.2 · Definisi

- **A.** Risk register
- **B.** Incident log
- **C.** Asset inventory
- **D.** Statement of work

16. A risk assessment uses categories such as "low, medium, high" based on expert judgment rather than monetary values. Which type of analysis is this?

Objektif 5.2 · Skenario

- **A.** Monte Carlo
- **B.** Qualitative
- **C.** Quantitative
- **D.** ALE-based

17. Which statement BEST describes risk appetite?

Objektif 5.2 · Skenario

- **A.** The amount of risk an organization is willing to accept in pursuit of its objectives
- **B.** The maximum downtime a system can tolerate
- **C.** The list of risks identified during an assessment
- **D.** The cost of implementing security controls

18. A KRI shows the number of unpatched critical vulnerabilities rising for three consecutive months. What is the PRIMARY purpose of this metric?

Objektif 5.2 · Skenario

- **A.** Replacing the need for vulnerability scans
- **B.** Early warning that risk exposure is increasing, prompting action
- **C.** Calculating the annual security budget
- **D.** Meeting the requirement to publish a security report

19. Which risk assessment approach is MOST appropriate for a rapidly changing cloud environment?

Objektif 5.2 · Skenario

- **A.** Ad hoc assessment after an incident only
- **B.** Continuous assessment with automated monitoring
- **C.** One-time assessment at project start
- **D.** Annual assessment only

20. A risk matrix plots likelihood against impact. A risk with high likelihood and high impact should be treated how?

Objektif 5.2 · Skenario

- **A.** Deferred to the next budget cycle
- **B.** Prioritized for immediate mitigation or avoidance
- **C.** Accepted without further action
- **D.** Transferred without notifying management

21. Before signing a contract with a new cloud vendor, a company sends a detailed security questionnaire and reviews the vendor's SOC 2 report. Which process is this?

Objektif 5.3 · Skenario

- **A.** Penetration testing
- **B.** Internal audit
- **C.** Incident response
- **D.** Vendor due diligence

22. Which contract clause allows a company to inspect a vendor's security controls and records?

Objektif 5.3 · Skenario

- **A.** Non-disclosure
- **B.** Service level
- **C.** Indemnification
- **D.** Right-to-audit

23. Which document is used to define a preliminary understanding between two parties before a formal contract, often non-binding?

Objektif 5.3 · Perbandingan

- **A.** MOU
- **B.** SLA
- **C.** BPA
- **D.** SOW

24. An organization relies on a single SaaS provider for a critical function, and migrating would require rewriting integrations. Which risk is this?

Objektif 5.3 · Skenario

- **A.** Supply chain diversification
- **B.** Vendor lock-in
- **C.** Data sovereignty
- **D.** Shadow IT

25. A vendor subcontracts part of its service to another company without informing the customer. Which risk is MOST directly introduced?

Objektif 5.3 · Skenario

- **A.** Decreased licensing cost
- **B.** Unassessed fourth-party risk in the supply chain
- **C.** Increased network latency
- **D.** Loss of data sovereignty only

26. Which activity provides the MOST reliable evidence of a vendor's actual security posture over time?

Objektif 5.3 · Skenario

- **A.** Independent audit report covering a period (SOC 2 Type II)
- **B.** Vendor's marketing brochure
- **C.** A single phone interview with sales
- **D.** Vendor's self-assessment completed in one day

27. A company requires its cloud provider to notify it within 24 hours of any breach involving its data. Which document should contain this requirement?

Objektif 5.3 · Skenario

- **A.** Risk register
- **B.** Asset inventory
- **C.** Service level agreement or contract with security terms
- **D.** Acceptable use policy

28. A vendor's product is critical, but the vendor refuses any audit rights and provides no independent certifications. What is the MOST appropriate action?

Objektif 5.3 · Skenario

- **A.** Rely on the vendor's verbal assurance
- **B.** Document the risk and require compensating controls or choose another vendor
- **C.** Accept the contract without conditions
- **D.** Ignore the issue because the product is popular

29. Which agreement is specifically used when two organizations exchange data and defines how that data may be processed and protected?

Objektif 5.3 · Skenario

- **A.** MOU
- **B.** SOW
- **C.** Data processing agreement
- **D.** NDA

30. Under GDPR, which party determines the purposes and means of processing personal data?

Objektif 5.4 · Definisi

- **A.** Data subject
- **B.** Supervisory authority
- **C.** Data controller
- **D.** Data processor

31. A US healthcare provider must protect patient records and ensure only authorized staff can access them. Which regulation applies?

Objektif 5.4 · Skenario

- **A.** PCI DSS
- **B.** SOX
- **C.** FERPA
- **D.** HIPAA

32. A retailer accepts credit cards and must comply with requirements for storing and transmitting cardholder data. Which standard applies?

Objektif 5.4 · Skenario

- **A.** GDPR
- **B.** ISO 27001
- **C.** PCI DSS
- **D.** HIPAA

33. A company wants to demonstrate to customers that its security controls are designed appropriately at a specific point in time. Which report is MOST appropriate?

Objektif 5.4 · Skenario

- **A.** SOC 2 Type I
- **B.** SOC 2 Type II
- **C.** Penetration test report
- **D.** Risk assessment

34. Which framework provides a voluntary, risk-based set of cybersecurity practices organized into functions such as Identify, Protect, Detect, Respond, and Recover?

Objektif 5.4 · Skenario

- **A.** HIPAA Security Rule
- **B.** SOX
- **C.** NIST Cybersecurity Framework
- **D.** PCI DSS

35. A customer asks for written confirmation that a vendor's controls meet agreed requirements. Which document satisfies this?

Objektif 5.4 · Skenario

- **A.** Asset inventory
- **B.** Attestation/acknowledgement letter
- **C.** Risk register
- **D.** Incident report

36. Which is a potential consequence of non-compliance with a regulatory framework?

Objektif 5.4 · Skenario

- **A.** Fines, sanctions, reputational damage, and loss of license
- **B.** Increased bandwidth
- **C.** Faster incident response
- **D.** Reduced need for audits

37. A company processes EU residents' data and must respond to requests to access or delete personal data. Which concept is this?

Objektif 5.4 · Skenario

- **A.** Right-to-audit
- **B.** Data subject rights
- **C.** Data sovereignty
- **D.** Data minimization

38. Which statement BEST distinguishes an audit from an assessment?

Objektif 5.5 · Perbandingan

A. An assessment results in certification; an audit does not

B. They are identical activities with different names

C. An audit provides independent, formal verification against criteria; an assessment is often an internal evaluation of controls or maturity

D. An audit is always performed by employees; an assessment by regulators

39. An internal audit finds that 30% of servers are missing critical patches. What should happen NEXT?

Objektif 5.5 · Skenario

A. Document the finding, assign an owner, and track remediation to closure

B. Delete the finding to protect the team

C. Immediately fire the administrators

D. Wait for the external audit to confirm

40. Before an external audit, a company reviews its own controls and evidence. Which activity is this?

Objektif 5.5 · Skenario

A. Penetration test

B. Tabletop exercise

C. Threat hunt

D. Internal audit/readiness assessment

41. A company runs monthly phishing simulations and tracks how many users report suspicious emails. Which metric BEST demonstrates program improvement?

Objektif 5.6 · Skenario

A. Number of emails sent

B. Number of employees trained once

C. Total budget spent

D. Increased reporting rate and decreased click rate

42. An attacker holds the door open for an employee carrying boxes and enters the building without a badge. Which social engineering technique is this?

Objektif 5.6 · Skenario

A. Shoulder surfing

B. Pretexting

C. Phishing

D. Tailgating

43. Which training is MOST important for the finance department to prevent business email compromise?

Objektif 5.6 · Skenario

A. Server hardening

B. Verifying payment changes through a separate known phone number

C. Learning to create strong passwords only

D. Physical security awareness

44. A company wants to increase engagement in security training using points, badges, and leaderboards. Which technique is this?

Objektif 5.6 · Skenario

- **A.** Phishing simulation
- **B.** Tabletop exercise
- **C.** Role-based training
- **D.** Gamification

45. An employee finds a suspicious email and forwards it to the security team instead of clicking. Which behavior is being reinforced?

Objektif 5.6 · Skenario

- **A.** Separation of duties
- **B.** Incident reporting culture
- **C.** Clean desk policy
- **D.** Least privilege

46. Which policy BEST reduces the risk of sensitive documents being photographed or removed from the office?

Objektif 5.6 · Skenario

- **A.** Password complexity policy
- **B.** Change management policy
- **C.** Data retention policy
- **D.** Clean desk and clear screen policy

47. Which awareness topic is MOST relevant for employees who work remotely using personal Wi-Fi?

Objektif 5.6 · Skenario

- **A.** Risks of unsecured networks and the need for VPN/secure configuration
- **B.** How to rack servers
- **C.** Fire suppression procedures
- **D.** Cable management standards

48. An insider threat program wants employees to recognize and report unusual behavior such as attempts to bypass controls. Which training element is MOST appropriate?

Objektif 5.6 · Skenario

- **A.** Scenario-based training with reporting channels
- **B.** Only annual policy acknowledgement
- **C.** Technical patch management training
- **D.** Fire drill training

49. A phishing simulation has a very low click rate, but few users report the simulated emails. What should the program focus on NEXT?

Objektif 5.6 · Skenario

- **A.** Increasing the difficulty of simulations only
- **B.** Ending the program because click rate is low
- **C.** Punishing users who did not report
- **D.** Encouraging reporting and simplifying the report process

50. Which document would a company use to define expected performance and availability of a service provided to a customer?

Objektif 5.1 · Skenario

A. AUP

B. SLA

C. MOU

D. NDA

BAGIAN II — KUNCI JAWABAN & PEMBAHASAN

Periksa jawaban setelah menyelesaikan satu domain penuh.

Kunci Domain 1 — General Security Concepts

1. B	2. A	3. C	4. D	5. B	6. C	7. B	8. B	9. A	10. D
11. D	12. A	13. C	14. C	15. C	16. B	17. B	18. C	19. A	20. A
21. C	22. C	23. A	24. B	25. B	26. A	27. A	28. A	29. A	30. A
31. B	32. B	33. D	34. B	35. A	36. B				

1. Jawaban B · Objektif 1.1

Badge reader dan biometric scanner adalah kontrol **technical (logical)** karena berbasis teknologi, dan bersifat **preventive** karena menghentikan akses sebelum terjadi. Kontrol physical adalah seperti pagar, kunci mekanis, atau penjaga; deterrent hanya bertujuan menakuti pelaku, bukan menolak akses.

2. Jawaban A · Objektif 1.1

Managerial (administrative) control adalah kontrol berbentuk kebijakan, prosedur, standar, dan proses tata kelola seperti risk assessment. Firewall dan honeypot bersifat technical, sedangkan motion sensor bersifat physical.

3. Jawaban C · Objektif 1.1

Kamera yang terlihat jelas, papan peringatan, dan pos penjaga dimaksudkan untuk **mencegah niat** pelaku — itu definisi deterrent. Kontrol corrective memulihkan setelah insiden, compensating menggantikan kontrol yang tidak bisa diterapkan, dan detective hanya mendeteksi (misalnya alarm yang tidak terlihat).

4. Jawaban D · Objektif 1.1

Karena patch tidak mungkin diterapkan, tim memakai kontrol lain sebagai pengganti — ini **compensating control**. Isolasi jaringan memang bersifat preventive juga, tetapi dalam konteks "menggantikan patch yang tidak tersedia", jawaban yang paling tepat adalah compensating.

5. Jawaban B · Objektif 1.1

Restore dari backup memulihkan sistem ke kondisi normal setelah insiden terjadi, sehingga termasuk **corrective**. Detective hanya menemukan masalah, sedangkan deterrent dan directive bekerja sebelum insiden.

6. Jawaban C · Objektif 1.1

Directive control mengarahkan perilaku melalui aturan tertulis, kebijakan, atau instruksi. Kebijakan lock screen tidak memblokir secara teknis, tidak mendeteksi, dan bukan kontrol fisik.

7. Jawaban B · Objektif 1.2

Hashing membuktikan data tidak berubah — itu **integrity**. Confidentiality dijaga dengan enkripsi, availability dengan redundansi, sedangkan non-repudiation membutuhkan bukti identitas seperti digital signature.

8. Jawaban B · Objektif 1.2

Authentication = membuktikan siapa Anda; **authorization** = menentukan apa yang boleh Anda lakukan; **accounting** = mencatat apa yang Anda lakukan (log/audit trail). Urutannya selalu identifikasi → autentikasi → otorisasi → akuntansi.

9. Jawaban A · Objektif 1.2

Password + kode OTP adalah **authentication** (plus identification di awal), dan pemeriksaan role terhadap modul payroll adalah **authorization**. Accounting baru terjadi saat aktivitas pengguna dicatat.

10. Jawaban D · Objektif 1.2

Dalam model NIST SP 800-207, **policy engine** mengambil keputusan (allow/deny) berdasarkan kebijakan dan sinyal konteks. **Policy administrator** mengeksekusi keputusan dengan membuat/menghapus sesi, dan **policy enforcement point** menegakkan keputusan pada lalu lintas aktual.

11. Jawaban D · Objektif 1.2

Microsegmentation membagi jaringan menjadi segmen kecil dengan aturan akses spesifik, menghilangkan implicit trust antar sistem. Implicit trust zone justru konsep yang harus dihilangkan dalam zero trust.

12. Jawaban A · Objektif 1.2

Honeytoken adalah data umpan (file, record, kredensial) yang tidak punya kegunaan sah; siapa pun yang menyentuhnya hampir pasti penyerang atau insider. Honeypot adalah sistem/ host umpan, bukan artefak data.

13. Jawaban C · Objektif 1.2

Gap analysis membandingkan kondisi saat ini dengan target (misalnya ISO 27001 atau NIST CSF) lalu mengidentifikasi kekurangan. Opsi lain adalah aktivitas operasional spesifik, bukan analisis kesenjangan menyeluruh.

14. Jawaban C · Objektif 1.3

Backout plan (rollback plan) menjelaskan cara mengembalikan sistem ke kondisi semula bila perubahan gagal. Impact analysis menilai dampak perubahan, maintenance window menentukan jadwal, dan approval adalah persetujuan itu sendiri.

15. Jawaban C · Objektif 1.3

Persetujuan, pengujian, komunikasi stakeholder, dan jadwal perubahan adalah elemen **change management**. Tujuannya mencegah perubahan yang tidak terdokumentasi dan memicu gangguan produksi.

16. Jawaban B · Objektif 1.4

Digital signature mengenkripsi hash pesan dengan private key pengirim, sehingga penerima dapat memverifikasi **integrity**, memastikan identitas pengirim (**authentication**), dan penandatangan tidak bisa menyangkal (**non-repudiation**). Signature tidak menyembunyikan isi pesan, jadi bukan confidentiality.

17. Jawaban B · Objektif 1.4

Key escrow menyimpan salinan kunci pada pihak ketiga tepercaya untuk keperluan pemulihan. Key rotation adalah pergantian kunci berkala, key stretching memperkuat password lemah, dan key exchange adalah pertukaran kunci (misalnya Diffie-Hellman).

18. Jawaban C · Objektif 1.4

TPM adalah chip kriptografi pada satu perangkat (untuk BitLocker, measured boot, attestation). **HSM** adalah perangkat/ layanan khusus yang diperkuat untuk operasi kriptografi bervolume tinggi dan penyimpanan kunci pada level organisasi.

19. Jawaban A · Objektif 1.4

OCSP (Online Certificate Status Protocol) memungkinkan pemeriksaan status satu sertifikat secara real time tanpa mengunduh seluruh daftar. CRL adalah daftar lengkap yang diunduh, CSR adalah permintaan sertifikat, dan trust anchor adalah root certificate yang dipercaya.

20. Jawaban A · Objektif 1.4

Salt memastikan dua pengguna dengan password sama menghasilkan hash berbeda, sehingga rainbow table yang sudah dihitung sebelumnya tidak berguna. Salt bukan enkripsi dan tidak membuat hash bisa dibalik.

21. Jawaban C · Objektif 1.4

Key stretching (misalnya PBKDF2, bcrypt, Argon2) menerapkan fungsi hash berulang kali dengan biaya komputasi tinggi sehingga setiap tebakan menjadi lambat. Salting mencegah rainbow table tetapi tidak memperlambat per tebakan.

22. Jawaban C · Objektif 1.4

Hash bersifat satu arah (tidak bisa dikembalikan) dan dipakai untuk integritas/verifikasi. **Enkripsi** bersifat reversibel dengan kunci yang tepat dan melindungi kerahasiaan.

23. Jawaban A · Objektif 1.4

Blockchain mengaitkan setiap blok dengan hash blok sebelumnya sehingga perubahan satu blok merusak seluruh rantai — sifatnya tamper-evident (integritas). Blockchain tidak otomatis menjamin kerahasiaan karena isinya bisa terbaca semua node.

24. Jawaban B · Objektif 1.4

TPM menyegel kunci ke platform dan melakukan **measured boot**; kunci hanya dilepas bila PCR (measurement) sesuai. HSM melayani banyak sistem, sedangkan secure enclave melindungi kode/data dalam CPU, bukan mengukur boot.

25. Jawaban B · Objektif 1.4

Kriptografi asimetris dipakai untuk autentikasi dan menyepakati kunci sesi karena mahal secara komputasi; transfer data massal kemudian memakai **symmetric** (AES) yang jauh lebih cepat. Asymmetric tetap bisa mengenkripsi data kecil, hanya tidak efisien.

26. Jawaban A · Objektif 1.4

FDE melindungi data saat disk dalam keadaan mati, tetapi file yang sudah dikopi ke media lain tidak lagi terlindungi. **File-level encryption** (atau container terenkripsi) tetap melekat pada file tersebut di mana pun ia berada.

27. Jawaban A · Objektif 1.4

S/MIME memberi enkripsi dan tanda tangan pada pesan email, sedangkan **IPsec** melindungi lalu lintas pada layer network (mode tunnel/transport). TLS melindungi hop transport, bukan isi email end-to-end.

28. Jawaban A · Objektif 1.4

Tokenization menukar data asli (misalnya nomor kartu kredit) dengan token yang tidak bermakna; pemetaan disimpan di vault. Data masking biasanya mengubah tampilan secara permanen (misalnya **--**-1234), sedangkan steganografi menyembunyikan data di dalam media lain.

29. Jawaban A · Objektif 1.4

Collision terjadi ketika dua input berbeda menghasilkan hash yang sama; MD5 dan SHA-1 sudah terbukti rentan. Downgrade menurunkan versi protokol, rainbow table menyerang password, dan brute force menebak kunci.

30. Jawaban A · Objektif 1.4

Downgrade attack memaksa kedua pihak memakai versi protokol atau cipher suite yang lebih lemah agar mudah diserang. Mitigasinya: menonaktifkan protokol lama dan mengaktifkan strict security settings di kedua sisi.

31. Jawaban B · Objektif 1.4

Dengan private key root CA, penyerang dapat menerbitkan sertifikat yang tampak sah untuk domain apa pun (misalnya bank), sehingga terjadi impersonation dan MITM. Inilah alasan root CA dijaga offline di HSM dan ada mekanisme revocation.

32. Jawaban B · Objektif 1.2

Access control vestibule (mantrap) adalah ruang kecil dengan dua pintu interlock untuk mencegah tailgating/piggybacking. Bollard adalah penghalang kendaraan, Faraday cage memblokir sinyal elektromagnetik.

33. Jawaban D · Objektif 1.2

Bollards adalah tiang penghalang fisik untuk mencegah kendaraan menabrak bangunan atau area terlarang. Lighting bersifat deterrent/detective, motion sensor detective, proximity reader untuk kontrol akses.

34. Jawaban B · Objektif 1.2

Server umpan adalah **honeypot**, sedangkan kredensial palsu di dalamnya adalah **honeytoken**. Kombinasi ini mendeteksi dan mempelajari teknik penyerang tanpa memberi akses ke aset nyata.

35. Jawaban A · Objektif 1.3

Emergency change tetap harus dicatat dan ditinjau (sering secara retroaktif) oleh CAB. Melewati dokumentasi menghilangkan jejak audit dan membuat rollback sulit; menunggu jadwal normal justru membiarkan risiko aktif.

36. Jawaban B · Objektif 1.3

SOP merinci langkah operasional, peran, dan verifikasi sehingga perubahan konsisten dan dapat diaudit. Kebijakan AUP mengatur perilaku pengguna; BIA dan risk register bukan instruksi teknis.

Kunci Domain 2 — Threats, Vulnerabilities, and Mitigations

1. C	2. A	3. A	4. C	5. C	6. D	7. B	8. A	9. D	10. B
11. D	12. D	13. A	14. A	15. B	16. A	17. C	18. B	19. D	20. D
21. C	22. C	23. B	24. A	25. A	26. B	27. C	28. D	29. D	30. A
31. C	32. D	33. B	34. D	35. A	36. D	37. D	38. A	39. D	40. C
41. C	42. C	43. D	44. D	45. D	46. C	47. B	48. D	49. D	50. C
51. A	52. C	53. D	54. D	55. B	56. A	57. B	58. C	59. B	60. D
61. D	62. A	63. C	64. A	65. B	66. A	67. D	68. B	69. C	70. A
71. B	72. A	73. C	74. C						

1. Jawaban C · Objektif 2.1

Ciri **nation-state/APT**: pendanaan besar, malware kustom, kampanye jangka panjang, dan motif spionase. Hacktivist termotivasi ideologi dan biasanya aksinya lebih terbuka; unskilled attacker memakai tool yang sudah ada; insider berada di dalam organisasi.

2. Jawaban A · Objektif 2.1

Aksi defacement dan kebocoran data untuk menyampaikan pesan politik adalah ciri **hacktivist** yang dimotivasi ideologi. Pencurian data untuk dijual atau spionase tidak sesuai dengan pola ini.

3. Jawaban A · Objektif 2.1

Insider threat adalah orang dengan akses sah yang menyalahgunakan aksesnya, termasuk karyawan yang akan keluar. Shadow IT lebih mengarah pada penggunaan teknologi tanpa persetujuan, bukan pencurian data dengan niat jahat.

4. Jawaban C · Objektif 2.1

Organized crime menjalankan serangan untuk keuntungan finansial dengan struktur bisnis, termasuk model RaaS dan afiliasi. Nation-state fokus pada spionase/geo-politik, hacktivist pada ideologi.

5. Jawaban C · Objektif 2.1

Shadow IT adalah penggunaan perangkat, aplikasi, atau layanan TI tanpa persetujuan/pengetahuan departemen TI. Risikonya: data tidak terklasifikasi, tidak terpantau DLP, dan sulit diaudit.

6. Jawaban D · Objektif 2.1

Unskilled attacker (script kiddie) memakai tool siap pakai tanpa memahami mekanismenya, biasanya untuk mencari korban acak. ATP/APT justru memiliki keahlian dan sumber daya tinggi.

7. Jawaban B · Objektif 2.1

Keduanya bisa memakai malware dan menyerang perusahaan. Yang membedakan adalah **sumber daya, sofistikasi, dan kesabaran** (kampanye bertahun-tahun) untuk tujuan strategis seperti spionase.

8. Jawaban A · Objektif 2.1

Organized crime dimotivasi uang (ransomware, penipuan, penjualan data). Hacktivist = ideologi, nation-state = spionase/strategi, insider bisa bermacam-macam (uang, dendam, kelalaian).

9. Jawaban D · Objektif 2.2

Serangan lewat **supply chain** memanfaatkan kepercayaan pada vendor/MSP/perangkat lunak pihak ketiga. Satu kompromi di penyedia dapat menyebar ke banyak pelanggan sekaligus.

10. Jawaban B · Objektif 2.2

Typosquatting mendaftarkan domain yang mirip (salah ketik, karakter mirip) untuk menipu pengguna. Watering hole adalah situs sah yang dikompromikan untuk menyerang kelompok tertentu.

11. Jawaban D · Objektif 2.2

Watering hole menyerang situs yang biasa dikunjungi target, lalu menyuntikkan malware khusus untuk kelompok tersebut. Spear phishing tetap berbasis pesan yang dikirim langsung ke korban.

12. Jawaban D · Objektif 2.2

BEC memalsukan identitas eksekutif/rekan bisnis untuk memicu transfer dana atau perubahan data pembayaran. Whaling adalah phishing yang menyasar eksekutif sebagai korban, bukan memalsukan eksekutif untuk menipu staf.

13. Jawaban A · Objektif 2.2

Smishing adalah phishing melalui SMS. Vishing melalui panggilan suara, phishing umumnya email, dan pretexting adalah teknik membangun alasan palsu (bisa dipakai di semua kanal).

14. Jawaban A · Objektif 2.2

Panggilan telepon (vishing) dengan cerita palsu yang meyakinkan (pretexting) untuk melewati prosedur help desk. Mitigasinya: verifikasi identitas melalui kanal terpisah dan prosedur reset MFA yang ketat.

15. Jawaban B · Objektif 2.2

Removable media (USB) dapat berisi malware atau melakukan HID attack saat dicolok. Kontrol: disable autorun, endpoint protection, dan kebijakan larangan memakai media tak dikenal.

16. Jawaban A · Objektif 2.2

Port 3389 (RDP) yang terbuka ke internet memperluas attack surface, dan **default credentials** memudahkan akses. Mitigasi: tutup port, gunakan VPN/jump host, dan ganti kredensial default.

17. Jawaban C · Objektif 2.2

EOL/unsupported system tidak lagi menerima patch, sehingga kerentanan yang sudah diketahui publik akan tetap terbuka. Zero-day adalah kerentanan yang belum diketahui vendor, berbeda konsep.

18. Jawaban B · Objektif 2.2

Bluesnarfing adalah pencurian data melalui koneksi Bluetooth, sedangkan bluejacking hanya mengirim pesan tak diminta. Deauthentication dan evil twin adalah serangan Wi-Fi.

19. Jawaban D · Objektif 2.2

File-based vector adalah file berbahaya (dokumen bermakro, installer, arsip) yang dieksekusi pengguna, baik dari unduhan maupun media lepas. **Message-based vector** menekankan kanal pesan seperti email, SMS, atau IM yang membawa tautan/lampiran.

20. Jawaban D · Objektif 2.2

Ini adalah serangan **supply chain** melalui penyedia perangkat lunak: pelanggan mempercayai update bertanda tangan dari vendor. Pertahanan: verifikasi hash/tanda tangan, code signing yang aman, dan pemantauan perilaku setelah update.

21. Jawaban C · Objektif 2.3

Buffer overflow menulis melebihi batas memori yang dialokasikan sehingga menimpa area lain, termasuk return address. Mitigasi: input validation, safe languages, ASLR, dan DEP.

22. Jawaban C · Objektif 2.3

Race condition TOCTOU (time-of-check to time-of-use) terjadi karena keadaan berubah antara pemeriksaan dan penggunaan. Mitigasi: operasi atomik, file locking, dan validasi ulang.

23. Jawaban B · Objektif 2.3

Pesan error SQL yang membocorkan sintaks menunjukkan input pengguna masuk ke query tanpa parameterisasi — **SQL injection**. Mitigasi utama: prepared statements/parameterized queries dan least privilege pada akun database.

24. Jawaban A · Objektif 2.3

Stored (persistent) XSS menyimpan payload di server sehingga tereksekusi pada semua pengunjung. Reflected XSS hanya muncul dari parameter yang dipantulkan kembali ke satu korban.

25. Jawaban A · Objektif 2.3

CSRF memanfaatkan sesi korban yang masih aktif untuk mengirim permintaan yang tidak diinginkan. Mitigasi: anti-CSRF token, SameSite cookie, dan verifikasi origin.

26. Jawaban B · Objektif 2.3

Directory traversal (path traversal) memakai ../ untuk keluar dari direktori yang diizinkan. Mitigasi: validasi path, gunakan allow list nama file, dan jalankan dengan hak minimal.

27. Jawaban C · Objektif 2.3

VM escape menembus isolasi hypervisor sehingga penyerang menguasai host dan VM lain. Mitigasi: patch hypervisor, matikan fitur tidak perlu, dan batasi akses manajemen.

28. Jawaban D · Objektif 2.3

VM sprawl adalah pertumbuhan VM tak terkendali tanpa inventaris dan patch, sehingga muncul sistem tak terkelola. Solusinya: inventaris otomatis, lifecycle management, dan decommissioning.

29. Jawaban D · Objektif 2.3

Misconfiguration cloud (bucket publik, IAM terlalu longgar, logging mati) adalah penyebab kebocoran data paling umum di cloud. Mitigasi: secure baseline, policy as code, dan pemindaian konfigurasi.

30. Jawaban A · Objektif 2.3

Zero-day adalah celah yang belum diketahui pembuat software, sehingga belum ada patch pada saat dieksploitasi. Mitigasi tidak bisa mengandalkan patching, melainkan deteksi perilaku, segmentasi, dan virtual patching.

31. Jawaban C · Objektif 2.3

Sideloading (memasang aplikasi dari luar toko resmi) membuka jalan bagi aplikasi berbahaya. **Jailbreaking/rooting** adalah membuka kunci sistem operasi, berbeda dari sekadar sideloading.

32. Jawaban D · Objektif 2.3

Perangkat **EOL** dengan firmware usang tidak lagi menerima patch dan sering memiliki kerentanan publik. Mitigasi: ganti perangkat, isolasi VLAN, dan batasi akses manajemen.

33. Jawaban B · Objektif 2.3

Kunci yang di-hardcode di source code dapat dibaca siapa pun yang memiliki akses repo — ini **improper key storage**. Kunci seharusnya disimpan di KMS/HSM dan dirotasi.

34. Jawaban D · Objektif 2.3

DLL injection memaksa proses yang sah memuat library berbahaya sehingga kode berjalan dalam konteks proses tersebut dan sulit terdeteksi. Ini sering dipakai malware untuk persistence dan menghindari deteksi.

35. Jawaban A · Objektif 2.3

Resource reuse terjadi ketika resource (disk, memori, IP) dialokasikan ulang tanpa sanitasi menyeluruh. Mitigasi: enkripsi disk, secure wipe, dan sanitasi sebelum reuse.

36. Jawaban D · Objektif 2.3

Hardware supply chain compromise menanam komponen atau backdoor pada perangkat fisik. Mitigasi: vendor vetting, inspeksi perangkat, dan pemantauan lalu lintas keluar.

37. Jawaban D · Objektif 2.4

Ransomware mengenkripsi data dan meminta tebusan. Mitigasi: backup offline teruji, segmentasi, dan deteksi perilaku enkripsi massal.

38. Jawaban A · Objektif 2.4

Worm menyebar sendiri melalui jaringan tanpa interaksi pengguna. Virus membutuhkan eksekusi pengguna/host, trojan menyamar sebagai program sah, logic bomb menunggu pemicu.

39. Jawaban D · Objektif 2.4

Rootkit bersembunyi di kernel/firmware dan memanipulasi tampilan sistem sehingga prosesnya tidak terlihat. Deteksinya sering memerlukan boot dari media tepercaya atau pemindaian offline.

40. Jawaban C · Objektif 2.4

Keylogger merekam input pengguna (dan sering clipboard) untuk mencuri kredensial. Indikatornya: koneksi keluar periodik, proses tak dikenal, dan alert EDR pada API hooking keyboard.

41. Jawaban C · Objektif 2.4

Logic bomb adalah kode yang dieksekusi saat kondisi tertentu terpenuhi (waktu, event, status akun). Pencegahannya: code review, kontrol perubahan, dan pencabutan akses segera saat terminasi.

42. Jawaban C · Objektif 2.4

Pola **beaconing** periodik ke C2 menunjukkan host terinfeksi dan tergabung dalam **botnet**. Tindakan: isolasi host, blokir IOC, dan analisis lateral movement.

43. Jawaban D · Objektif 2.4

Cryptomalware/cryptojacking memakai resource korban untuk menambang kripto; indikatornya konsumsi CPU/GPU tinggi, tagihan cloud naik, dan koneksi ke pool mining.

44. Jawaban D · Objektif 2.4

Fileless malware berjalan di memori memakai tool sah (PowerShell, WMI) sehingga tidak ada file untuk dipindai signature. Deteksi mengandalkan EDR, script block logging, dan analisis perilaku.

45. Jawaban D · Objektif 2.4

Evil twin adalah AP palsu dengan SSID sama untuk menipu klien agar terhubung dan menyerahkan kredensial/lalu lintas. Mitigasi: WPA3-Enterprise, certificate validation, dan wireless IDS.

46. Jawaban C · Objektif 2.4

Deauthentication attack mengirim frame deauth palsu sehingga klien terputus dan mencoba terhubung ulang — sering dikombinasikan dengan evil twin. Mitigasi: 802.11w (PMF) dan WPA3.

47. Jawaban B · Objektif 2.4

ARP poisoning memetakan IP gateway ke MAC penyerang sehingga terjadi on-path (MITM) di jaringan lokal. Mitigasi: dynamic ARP inspection, port security, dan segmentasi.

48. Jawaban D · Objektif 2.4

DNS poisoning (cache poisoning) mengubah pemetaan nama domain ke IP penyerang. Mitigasi: DNSSEC, resolver tepercaya, dan pemantauan perubahan record.

49. Jawaban D · Objektif 2.4

VLAN hopping (double tagging/switch spoofing) melewati isolasi VLAN. Mitigasi: matikan DTP, set port access secara eksplisit, dan gunakan VLAN native yang tidak dipakai.

50. Jawaban C · Objektif 2.4

MAC flooding membanjiri tabel CAM switch sehingga switch berperilaku seperti hub dan lalu lintas dapat disadap. Mitigasi: port security dengan batas MAC dan monitoring.

51. Jawaban A · Objektif 2.4

On-path (MITM) menempatkan penyerang di antara klien dan tujuan. Mitigasi: HTTPS dengan certificate pinning/HSTS, VPN, dan tidak mengabaikan peringatan sertifikat.

52. Jawaban C · Objektif 2.4

Replay attack menggunakan ulang kredensial/token yang sah. Mitigasi: timestamp, nonce, sequence number, dan token berumur pendek (short-lived).

53. Jawaban D · Objektif 2.4

Serangan **volumetric** membanjiri bandwidth (misalnya UDP/ICMP amplification). Application-layer DoS menghabiskan resource aplikasi (misalnya HTTP request mahal), dan SYN flood adalah salah satu teknik DDoS, bukan kategori yang paling tepat di sini.

54. Jawaban D · Objektif 2.4

Password spraying mencoba sedikit password umum ke banyak akun untuk menghindari lockout. Credential stuffing memakai pasangan username/password hasil kebocoran; dictionary attack menebak banyak password pada satu akun.

55. Jawaban B · Objektif 2.4

Credential stuffing memanfaatkan kredensial bocor dan kebiasaan reuse password. Mitigasi: cek terhadap breach corpus, MFA, dan passwordless.

56. Jawaban A · Objektif 2.4

Tabel **rainbow** memetakan hash ke password yang sudah dihitung sebelumnya; **salt** unik per pengguna membuat tabel tersebut tidak berguna. MFA dan panjang password tetap penting, tetapi bukan penangkal utama serangan offline ini.

57. Jawaban B · Objektif 2.4

Pola UNION SELECT adalah **SQL injection** untuk mengekstrak data dari tabel lain. Mitigasi: parameterized query, WAF sebagai lapisan tambahan, dan least privilege akun DB.

58. Jawaban C · Objektif 2.4

Impossible travel menandakan kredensial dipakai dari dua lokasi yang tidak mungkin dijangkau dalam waktu tersebut — indikasi akun dicuri. Perlu verifikasi dan pemeriksaan MFA.

59. Jawaban B · Objektif 2.4

Concurrent session usage di luar kebiasaan menandakan kredensial dibagikan atau dicuri. Kebijakan biasanya membatasi jumlah sesi simultan dan memicu verifikasi tambahan.

60. Jawaban D · Objektif 2.4

Lonjakan login gagal menunjukkan **brute force** atau sengaja mengunci akun agar korban menghubungi help desk (untuk menipu reset MFA). Ini juga indikator social engineering lanjutan.

61. Jawaban D · Objektif 2.4

Lonjakan trafik keluar yang tidak wajar dapat menandakan **exfiltration** atau C2. Indikator lain seperti resource consumption (CPU/disk) juga bisa menyertai pencurian data atau cryptomining.

62. Jawaban A · Objektif 2.4

Missing logs bisa berarti log dihapus, logging dimatikan, atau penyerang menutupi jejak. Bandingkan dengan sumber log lain (SIEM, syslog server) untuk memastikan.

63. Jawaban C · Objektif 2.4

Published/documented berarti penyerang mempublikasikan bukti akses atau data curian (leak site, paste site) untuk menekan korban. Ini juga sering menjadi awal negosiasi ransomware.

64. Jawaban A · Objektif 2.5

Segmentation membatasi lalu lintas antar zona; sistem tetap beroperasi tetapi attack surface-nya kecil. **Isolation** biasanya berarti memisahkan sepenuhnya (misalnya air-gap atau VM terisolasi) tanpa konektivitas produksi.

65. Jawaban B · Objektif 2.5

Allow list hanya mengizinkan program yang terdaftar (biasanya berdasarkan hash atau sertifikat), sehingga malware baru otomatis diblokir. Block list mudah dilewati karena hanya menolak yang sudah diketahui.

66. Jawaban A · Objektif 2.5

NAC (Network Access Control) memeriksa postur perangkat sebelum memberi akses, dan dapat menempatkan perangkat tidak patuh di VLAN remediasi. MDM mengelola perangkat, bukan mengontrol akses jaringan.

67. Jawaban D · Objektif 2.5

EDR mengumpulkan telemetri perilaku, mendeteksi teknik seperti process injection, dan dapat mengisolasi endpoint. HIDS hanya mendeteksi perubahan file/log, antivirus berbasis signature mudah dilewati malware baru.

68. Jawaban B · Objektif 2.5

DLP memeriksa konten (pola nomor identitas) dan memblokir/ mengarantina pengiriman ke tujuan tidak sah. FDE melindungi data saat perangkat hilang, bukan saat dikirim keluar.

69. Jawaban C · Objektif 2.5

Sandboxing menjalankan file di lingkungan terisolasi dan memantau perilakunya (network callbacks, file changes). Quarantine hanya menahan pesan, bukan menganalisis perilaku.

70. Jawaban A · Objektif 2.5

Secure baseline adalah konfigurasi acuan yang sudah diperkuat dan dipakai untuk semua deployment. Baseline harus diverifikasi berkala (configuration enforcement) agar tidak melenceng.

71. Jawaban B · Objektif 2.5

Decommissioning menghapus sistem dari produksi secara aman: cabut akses, sanitasi media, hapus record, dan perbarui inventaris. Ini mengurangi attack surface permanen.

72. Jawaban A · Objektif 2.5

MDM menerapkan kebijakan perangkat (enkripsi, PIN, remote wipe) dan dapat memisahkan data kerja dari data pribadi pada perangkat **BYOD**. NAC hanya mengontrol akses jaringan.

73. Jawaban C · Objektif 2.5

Host-based firewall dapat membatasi lalu lintas per host tanpa mengubah topologi jaringan. Segmentasi jaringan juga bisa, tetapi untuk aturan per-endpoint, host firewall lebih langsung.

74. Jawaban C · Objektif 2.5

Secure enclave adalah area terisolasi di dalam prosesor yang melindungi kode dan kunci dari OS utama. TPM adalah chip terpisah untuk menyimpan kunci/measurement, HSM adalah perangkat eksternal.

Kunci Domain 3 — Security Architecture

1. B	2. B	3. C	4. D	5. C	6. A	7. D	8. A	9. C	10. D
11. D	12. D	13. C	14. C	15. C	16. D	17. B	18. B	19. A	20. A
21. B	22. D	23. C	24. C	25. C	26. D	27. B	28. A	29. A	30. B
31. D	32. B	33. B	34. C	35. A	36. B	37. C	38. B	39. D	40. D
41. C	42. C	43. A	44. B	45. C	46. C	47. A	48. B		

1. Jawaban B · Objektif 3.1

Pada **SaaS**, penyedia mengelola aplikasi, OS, dan infrastruktur; pelanggan tetap bertanggung jawab atas **identitas, akses, dan data** (termasuk klasifikasi dan berbagi data). Patch aplikasi dan hypervisor menjadi tanggung jawab penyedia.

2. Jawaban B · Objektif 3.1

Pada **IaaS**, pelanggan mengelola OS tamu, patch, konfigurasi keamanan, dan aturan firewall/security group. Lapisan fisik, hypervisor, dan backbone berada pada penyedia.

3. Jawaban C · Objektif 3.1

PaaS menyediakan runtime dan platform terkelola; tim hanya bertanggung jawab atas aplikasi, konfigurasi, dan data. IaaS menyediakan VM mentah, SaaS menyediakan aplikasi jadi.

4. Jawaban D · Objektif 3.1

Hybrid cloud menggabungkan on-premises dengan cloud publik. Multi-cloud berarti memakai dua atau lebih penyedia cloud publik, sedangkan private cloud sepenuhnya dedicated untuk satu organisasi.

5. Jawaban C · Objektif 3.1

IaC memungkinkan infrastruktur didefinisikan dan direview seperti kode, sehingga konsisten dan dapat diaudit. Risikonya: kesalahan konfigurasi menyebar cepat, sehingga pipeline perlu pemeriksaan keamanan (policy as code).

6. Jawaban A · Objektif 3.1

Pada **serverless**, OS dikelola penyedia sehingga risiko bergeser ke **izin fungsi (IAM), secret, dan dependency**. Fungsi dengan izin berlebihan adalah kesalahan umum yang dapat dieksploitasi.

7. Jawaban D · Objektif 3.1

Microservices memecah aplikasi menjadi layanan kecil dengan API. Keuntungan: isolasi kegagalan dan deployment independen; risikonya: permukaan API luas, autentikasi antar-layanan rumit, dan perlu service mesh/mTLS.

8. Jawaban A · Objektif 3.1

Container berbagi kernel host, sehingga isolasinya lebih lemah daripada VM. Mitigasi: minimal base image, tidak menjalankan sebagai root, seccomp/AppArmor, dan pemisahan host untuk beban kerja sensitif.

9. Jawaban C · Objektif 3.1

Sistem **embedded/RTOS** menuntut determinisme waktu dan ketersediaan tinggi, sehingga patch dan agen keamanan berat sulit diterapkan. Pendekatannya: segmentasi, kontrol jaringan, dan pemantauan pasif.

10. Jawaban D · Objektif 3.1

Pada **ICS/SCADA**, gangguan dapat membahayakan nyawa dan peralatan, sehingga **availability dan safety** menjadi prioritas, diikuti integritas. Confidentiality tetap penting, tetapi bukan prioritas utama.

11. Jawaban D · Objektif 3.1

Network slicing memisahkan jaringan logis dengan karakteristik dan kebijakan masing-masing, sehingga gangguan atau serangan pada satu slice tidak otomatis meluas. Enkripsi aplikasi tetap diperlukan.

12. Jawaban D · Objektif 3.1

SDN memisahkan control plane (controller) dari data plane (switch), sehingga kebijakan dapat diprogram terpusat. Kontroler menjadi aset kritis yang harus diamankan.

13. Jawaban C · Objektif 3.2

Fail-open mengutamakan ketersediaan: saat perangkat gagal, semua lalu lintas diizinkan sehingga kebijakan keamanan hilang. **Fail-closed** lebih aman tetapi berisiko memutus layanan.

14. Jawaban C · Objektif 3.2

IDS biasanya **passive** (menerima salinan trafik dari TAP/SPAN) dan hanya memberi alert. IPS ditempatkan **inline** sehingga dapat memblokir paket secara real time.

15. Jawaban C · Objektif 3.2

TLS inspection melakukan dekripsi, inspeksi, lalu enkripsi ulang; perangkat klien harus mempercayai CA internal yang dipakai untuk menandatangani ulang. Ini menimbulkan isu privasi dan harus dikecualikan untuk kategori tertentu (misalnya perbankan).

16. Jawaban D · Objektif 3.2

WAF (Web Application Firewall) memeriksa payload HTTP dan dapat memblokir pola serangan aplikasi. Firewall layer 4 hanya melihat IP/port, load balancer membagi trafik, ACL router memfilter alamat/port.

17. Jawaban B · Objektif 3.2

UTM (Unified Threat Management) menggabungkan beberapa fungsi keamanan dalam satu perangkat. Kelemahannya: satu titik kegagalan dan potensi penurunan performa saat semua fitur aktif.

18. Jawaban B · Objektif 3.2

ZTNA memberikan akses per aplikasi berdasarkan identitas dan postur perangkat, tanpa mengekspos jaringan internal. VPN klasik memberi akses jaringan luas (network-level) setelah terhubung.

19. Jawaban A · Objektif 3.2

IPsec melindungi lalu lintas pada layer network dan mendukung banyak protokol dalam satu tunnel (mode tunnel untuk site-to-site). TLS hanya melindungi aplikasi tertentu, SSH untuk sesi administratif.

20. Jawaban A · Objektif 3.2

SASE menggabungkan SD-WAN dengan layanan keamanan cloud (secure web gateway, CASB, ZTNA, firewall-as-a-service). SD-WAN hanya mengoptimalkan konektivitas WAN.

21. Jawaban B · Objektif 3.2

Jump host/bastion terpusat di subnet manajemen, dengan MFA, logging, dan akses terbatas. Ini mengurangi attack surface dibandingkan mengekspos SSH/RDP langsung.

22. Jawaban D · Objektif 3.2

DMZ memisahkan sistem yang dapat diakses publik dari jaringan internal, dengan aturan ketat untuk koneksi keluar. Menempatkan database di DMZ justru meningkatkan risiko.

23. Jawaban C · Objektif 3.2

TAP/passive sensor menyalin trafik tanpa berada di jalur data, sehingga tidak menambah latensi atau titik kegagalan. Konsekuensinya, sensor tidak dapat memblokir trafik.

24. Jawaban C · Objektif 3.2

Agent-based memberi visibilitas mendalam (proses, file, registry) tetapi perlu dipasang dan dirawat di setiap host. **Agentless** memakai data jaringan/API, lebih mudah diterapkan tetapi kurang detail.

25. Jawaban C · Objektif 3.3

Dalam skema umum SY0-701, urutan dari paling sensitif: **extremely sensitive > sensitive > confidential > private > public**. Extremely sensitive mencakup data yang kebocorannya dapat menyebabkan kerugian besar (misalnya rahasia dagang inti).

26. Jawaban D · Objektif 3.3

Data sovereignty mengharuskan data tunduk pada hukum negara tempat data berada, sehingga lokasi penyimpanan dan replikasi harus dibatasi. Ini memengaruhi pilihan region cloud dan penyedia.

27. Jawaban B · Objektif 3.3

Data masking menyamarkan sebagian data sehingga tetap terlihat formatnya tetapi tidak dapat dipakai. Tokenization mengganti seluruh nilai dengan token yang dipetakan di vault.

28. Jawaban A · Objektif 3.3

Tokenization membuat data curian tidak berguna tanpa akses ke vault, dan dapat mengurangi cakupan kepatuhan (PCI DSS). Token memang dapat dipetakan kembali, tetapi hanya oleh sistem berwenang.

29. Jawaban A · Objektif 3.3

Anonymization menghapus atau menggeneralisasi identitas sehingga data tidak dapat dikaitkan kembali ke individu. Enkripsi dan tokenization masih memungkinkan re-identifikasi bila kunci/vault tersedia.

30. Jawaban B · Objektif 3.3

Tanpa **retention policy**, data lama menumpuk dan memperbesar dampak kebocoran serta melanggar kewajiban regulasi. Retention harus menentukan berapa lama disimpan dan bagaimana dihancurkan.

31. Jawaban D · Objektif 3.3

SSD memakai wear leveling sehingga overwrite tidak menjangkau semua sel; **physical destruction** atau **crypto-erase** (jika terenkripsi) adalah pilihan aman. Format cepat dan hapus partisi tidak menghilangkan data.

32. Jawaban B · Objektif 3.3

CASB memberikan visibilitas dan kontrol atas penggunaan cloud (shadow IT), termasuk blokir unggahan ke layanan tidak disetujui. NAC mengontrol akses jaringan perangkat, bukan isi unggahan.

33. Jawaban B · Objektif 3.3

Data in transit (in motion) dilindungi oleh TLS/IPsec. Data at rest dilindungi enkripsi disk/database, dan data in use dilindungi secure enclave/confidential computing.

34. Jawaban C · Objektif 3.3

Data minimization mengumpulkan hanya data yang benar-benar diperlukan untuk tujuan tertentu, mengurangi risiko dan kewajiban kepatuhan.

35. Jawaban A · Objektif 3.4

Active-active di dua lokasi menjalankan beban kerja bersamaan sehingga kegagalan satu site tidak menghentikan layanan dan data direplikasi sinkron. Warm site masih butuh waktu pemulihan; RAID hanya melindungi kegagalan disk.

36. Jawaban B · Objektif 3.4

RPO (Recovery Point Objective) menentukan berapa lama data boleh hilang — menentukan frekuensi backup/replikasi. **RTO** adalah waktu maksimal pemulihan layanan, MTTR waktu perbaikan rata-rata, MTBF waktu antar-kegagalan.

37. Jawaban C · Objektif 3.4

Hot site memiliki infrastruktur lengkap dan data terbaru sehingga dapat mengambil alih hampir seketika. Warm site punya sebagian infrastruktur, cold site hanya ruang dan daya.

38. Jawaban B · Objektif 3.4

Tabletop exercise adalah diskusi skenario untuk menguji prosedur, peran, dan komunikasi tanpa mengubah sistem. Failover test benar-benar memindahkan beban kerja, parallel processing menjalankan site sekunder bersamaan.

39. Jawaban D · Objektif 3.4

3-2-1: tiga salinan data, pada dua jenis media berbeda, dengan satu salinan di lokasi terpisah. Tujuannya melindungi dari kegagalan perangkat, bencana, dan ransomware yang menyebar.

40. Jawaban D · Objektif 3.4

Geographic dispersion menyebar beban ke beberapa lokasi, dan **platform diversity/multi-cloud** mengurangi risiko kegagalan atau lock-in satu penyedia. Keduanya meningkatkan ketahanan.

41. Jawaban C · Objektif 3.4

UPS hanya jembatan sementara; jika generator gagal, sistem akan mati setelah baterai habis. Karena itu generator harus diuji berkala dan bahan bakar dipantau.

42. Jawaban C · Objektif 3.4

Tanpa **sticky sessions** atau penyimpanan sesi terpusat, pengguna berpindah server dan kehilangan sesi. Solusi umum: session store bersama (Redis) atau cookie berbasis token.

43. Jawaban A · Objektif 3.4

Point-in-time recovery memakai backup penuh + log transaksi berkelanjutan sehingga database dapat dipulihkan ke detik tertentu. Backup mingguan saja tidak memenuhi kebutuhan 24 jam.

44. Jawaban B · Objektif 3.4

Availability = MTBF / (MTBF + MTTR) = 2000 / 2004 ≈ **99.8%**. Ini setara downtime sekitar 1,75 jam per tahun.

45. Jawaban C · Objektif 3.4

Parallel processing menjalankan sistem primer dan sekunder bersamaan untuk memvalidasi hasil sebelum beralih penuh. Ini lebih aman daripada failover penuh karena primer tetap tersedia.

46. Jawaban C · Objektif 3.4

Backup pada sistem yang sama rentan ikut terhapus saat ransomware atau kegagalan storage. Prinsip **3-2-1** membutuhkan salinan di media dan lokasi berbeda, idealnya satu offline/immutable.

47. Jawaban A · Objektif 3.1

API gateway memusatkan autentikasi, validasi skema, rate limiting, dan logging, sehingga service internal tidak terekspos langsung. Ini juga memudahkan inventaris endpoint.

48. Jawaban B · Objektif 3.2

802.1X + NAC memeriksa identitas perangkat dan postur (domain join, patch) sebelum menempatkannya di VLAN yang tepat. MAC allow list mudah dipalsukan dan tidak memeriksa postur.

Kunci Domain 4 — Security Operations

1. A	2. B	3. A	4. A	5. D	6. D	7. D	8. C	9. A	10. D
11. C	12. A	13. A	14. C	15. D	16. D	17. B	18. D	19. B	20. B
21. C	22. D	23. B	24. B	25. A	26. B	27. B	28. C	29. D	30. B
31. C	32. D	33. A	34. A	35. A	36. C	37. D	38. C	39. A	40. B
41. C	42. D	43. D	44. A	45. B	46. D	47. C	48. A	49. C	50. A
51. C	52. D	53. B	54. B	55. D	56. B	57. D	58. B	59. A	60. B
61. A	62. A	63. B	64. A	65. B	66. C	67. C	68. C	69. C	70. A
71. A	72. C	73. B	74. B	75. D	76. C	77. A	78. C		

1. Jawaban A · Objektif 4.1

Hardening mengurangi attack surface dengan menonaktifkan layanan tidak perlu, menghapus akun default, dan menerapkan konfigurasi aman. Patching hanya menutup kerentanan yang sudah diketahui.

2. Jawaban B · Objektif 4.1

WPA3-Enterprise + 802.1X memberi autentikasi per pengguna dan mendukung EAP-TLS berbasis sertifikat. PSK memakai kunci bersama yang dapat dibagikan; WEP sudah usang dan mudah dipecahkan.

3. Jawaban A · Objektif 4.1

MDM menerapkan kebijakan perangkat dan dapat memisahkan data kerja (container/MAM) dari data pribadi. Ini penting pada model **BYOD/COPE**.

4. Jawaban A · Objektif 4.1

Sideloading melewati kurasi toko aplikasi sehingga malware, spyware, atau aplikasi berbahaya bisa terpasang. Kebijakan MDM biasanya memblokir sumber tidak dikenal.

5. Jawaban D · Objektif 4.1

VDI/application virtualization menjalankan aplikasi dan data di lingkungan terkontrol, sehingga perangkat pribadi tidak menyimpan data perusahaan. FDE pada perangkat pribadi sulit ditegakkan.

6. Jawaban D · Objektif 4.1

Menonaktifkan modul/layanan tidak terpakai dan menghapus aplikasi contoh menghilangkan jalur serangan yang tidak perlu. Menambah resource tidak mengurangi attack surface.

7. Jawaban D · Objektif 4.1

Allow listing hanya mengizinkan binary bertanda tangan/terdaftar, sehingga malware tanpa signature tidak dapat berjalan. Ini termasuk teknik hardening endpoint.

8. Jawaban C · Objektif 4.1

Physical destruction menjamin data tidak dapat dipulihkan, bahkan dari komponen disk. Quick format dan penghapusan file hanya menghapus referensi, bukan data.

9. Jawaban A · Objektif 4.2

Asset management mencakup inventaris, penemuan (discovery/enumeration), dan pelacakan kepemilikan. Tanpa itu, pemindaian dan patching tidak lengkap karena aset tak dikenal (shadow assets) terlewat.

10. Jawaban D · Objektif 4.2

Asset tag dan catatan penugasan menghubungkan perangkat dengan pemilik/pengguna, lokasi, dan status. Ini penting untuk audit, pemulihan, dan investigasi.

11. Jawaban C · Objektif 4.2

Perangkat multifungsi menyimpan gambar dokumen di disk internal; **sanitasi/destruksi** media tersebut mencegah kebocoran data. Mengganti password tidak menghapus data lama.

12. Jawaban A · Objektif 4.2

Certification (sertifikat sanitasi/destruksi) mendokumentasikan metode dan hasil sehingga organisasi dapat membuktikan kepatuhan. Chain of custody berkaitan dengan bukti forensik.

13. Jawaban A · Objektif 4.3

Temuan yang tidak dapat dieksploitasi karena layanan nonaktif adalah **false positive**; dokumentasikan bukti dan tutup dengan justifikasi. Ini berbeda dari false negative (kerentanan nyata yang tidak terdeteksi).

14. Jawaban C · Objektif 4.3

Temporal mempertimbangkan faktor yang berubah seiring waktu (exploit code availability, remediation level). **Base** adalah sifat intrinsik, **environmental** disesuaikan dengan konteks organisasi.

15. Jawaban D · Objektif 4.3

Prioritas risiko mempertimbangkan **eksposur, exploitability, dan dampak bisnis**, bukan hanya skor mentah. Ini juga alasan CVSS environmental score dan threat intelligence dipakai.

16. Jawaban D · Objektif 4.3

Exception yang terdokumentasi dengan kontrol kompensasi (segmentasi, WAF rule, monitoring) dan tanggal review adalah praktik yang benar. Menyembunyikan temuan melanggar tata kelola.

17. Jawaban B · Objektif 4.3

Rescan/validation membuktikan perbaikan berhasil dan tidak ada regresi. Verifikasi juga dapat memakai audit konfigurasi atau uji eksploitasi terkontrol.

18. Jawaban D · Objektif 4.3

Responsible disclosure memberi vendor waktu memperbaiki sebelum detail dipublikasikan. Bug bounty adalah program berhadiah, pen test adalah pengujian terkontrak, threat hunting mencari ancaman aktif.

19. Jawaban B · Objektif 4.3

Rules of engagement menetapkan ruang lingkup, batasan, jadwal, dan kontak darurat pen test sehingga pengujian legal dan aman. SLA mengatur tingkat layanan, bukan aktivitas pengujian.

20. Jawaban B · Objektif 4.3

Credentialed scan masuk ke sistem dan memeriksa patch serta konfigurasi secara akurat. Unauthenticated scan hanya melihat dari luar dan lebih banyak false positive/negative.

21. Jawaban C · Objektif 4.3

Shift-left: memindai image saat build/pipeline sehingga kerentanan tidak pernah mencapai produksi. Pemindaian tahunan terlalu lambat untuk lingkungan yang sering berubah.

22. Jawaban D · Objektif 4.4

SIEM mengumpulkan, menormalkan, dan mengorelasikan log untuk deteksi serta investigasi. NetFlow hanya metadata trafik, WAF melindungi aplikasi web, NAC mengontrol akses perangkat.

23. Jawaban B · Objektif 4.4

SOAR mengotomatiskan playbook respons: enrichment, ticketing, dan tindakan seperti blokir IP. SIEM berfokus pada pengumpulan dan korelasi, bukan orkestrasi tindakan.

24. Jawaban B · Objektif 4.4

NetFlow memberi metadata aliran (source/destination, port, byte count) dengan overhead rendah. Packet capture menyimpan isi paket dan jauh lebih besar.

25. Jawaban A · Objektif 4.4

Alert tuning mengurangi false positive dengan mengecualikan perilaku yang diketahui aman, tanpa mematikan deteksi lain. Mengabaikan seluruh host berisiko melewatkan serangan nyata.

26. Jawaban B · Objektif 4.4

EDR merekam eksekusi proses, command line, dan interaksi API sehingga aktivitas fileless dapat terlihat. Firewall/NetFlow hanya menunjukkan koneksi jaringan.

27. Jawaban B · Objektif 4.4

DNS filtering/threat intel dapat memblokir atau menandai resolusi ke domain jahat (C2, phishing). Ini juga membantu menemukan host yang terinfeksi meski trafiknya terenkripsi.

28. Jawaban C · Objektif 4.4

SNMPv3 mendukung autentikasi dan enkripsi, sedangkan v1/v2c mengirim community string dalam plaintext. Telnet dan TFTP juga tidak terenkripsi.

29. Jawaban D · Objektif 4.4

FIM memantau perubahan file kritis dengan hash dan memberi alert saat ada modifikasi tak terduga — indikasi persistence atau backdoor.

30. Jawaban B · Objektif 4.5

DNS filtering memblokir resolusi domain berbahaya untuk seluruh jaringan, termasuk perangkat yang tidak bisa dipasangi agen. Ini lapisan pertahanan tambahan, bukan pengganti endpoint protection.

31. Jawaban C · Objektif 4.5

LDAPS membungkus LDAP dalam TLS (port 636) sehingga kredensial dan query tidak dikirim plaintext. LDAP 389 tanpa StartTLS rentan disadap.

32. Jawaban D · Objektif 4.5

SPF mendaftarkan IP/server yang diizinkan mengirim email untuk domain. **DKIM** menandatangani pesan, **DMARC** memberi kebijakan berdasarkan hasil SPF/DKIM dan laporan.

33. Jawaban A · Objektif 4.5

DMARC dengan p=reject memerintahkan penolakan pesan yang gagal alignment, dan rua mengirim laporan agregat. SPF saja tidak memberi kebijakan penanganan atau laporan.

34. Jawaban A · Objektif 4.5

SSH menyediakan sesi administratif terenkripsi dan terautentikasi. FTP, HTTP, dan SNMPv1 mengirim data (termasuk kredensial) tanpa enkripsi.

35. Jawaban A · Objektif 4.5

UEBA (User and Entity Behavior Analytics) membangun baseline perilaku dan menandai anomali seperti akses data masif atau login di luar kebiasaan — berguna untuk insider threat.

36. Jawaban C · Objektif 4.5

Credential Guard mengisolasi secret (NTLM hash, Kerberos TGT) dari LSASS sehingga sulit diambil dengan Mimikatz. AutoPlay dan SMBv1 justru meningkatkan risiko.

37. Jawaban D · Objektif 4.5

Device control (bagian dari endpoint protection/Group Policy) dapat membedakan kelas perangkat dan memblokir storage massal tanpa mematikan HID. Ini mengurangi risiko exfiltration dan infeksi via USB.

38. Jawaban C · Objektif 4.6

Deprovisioning harus menonaktifkan/menghapus akun, mencabut token, dan memindahkan data segera saat karyawan keluar. Akun yatim (orphaned account) adalah temuan audit yang serius.

39. Jawaban A · Objektif 4.6

SSO memungkinkan satu autentikasi untuk banyak aplikasi melalui trust ke IdP. Risikonya: satu kredensial yang dicuri membuka banyak aplikasi, sehingga MFA dan Conditional Access wajib.

40. Jawaban B · Objektif 4.6

SAML mengirim assertion XML tentang identitas dan atribut untuk SSO enterprise. **OAuth 2.0** mendelegasikan akses (misalnya aplikasi pihak ketiga ke API) memakai access token; autentikasi di atas OAuth dilakukan oleh **OIDC**.

41. Jawaban C · Objektif 4.6

Kerberos memakai KDC, TGT, dan service ticket untuk autentikasi mutual dalam domain. RADIUS/TACACS+ untuk AAA jaringan, LDAP untuk query direktori.

42. Jawaban D · Objektif 4.6

RADIUS (UDP 1812/1813) umum untuk AAA jaringan dan mengenkripsi password saja; **TACACS+** (TCP 49) memisahkan authentication, authorization, accounting dan mengenkripsi seluruh body — sering dipakai untuk admin perangkat.

43. Jawaban D · Objektif 4.6

LDAP adalah protokol direktori untuk membaca/mengubah objek seperti user dan group. Aksesnya harus melalui LDAPS/StartTLS agar kredensial tidak terekspos.

44. Jawaban A · Objektif 4.6

DAC (Discretionary Access Control) memberi pemilik resource kebebasan menetapkan izin. **MAC** memakai label klasifikasi dan kebijakan sistem, **RBAC** berbasis peran, **ABAC** berbasis atribut.

45. Jawaban B · Objektif 4.6

MAC (Mandatory Access Control) memakai label keamanan dan kebijakan yang ditetapkan sistem (misalnya SELinux, Bell-LaPadula). Pengguna tidak dapat menurunkan klasifikasi atau membagikan akses.

46. Jawaban D · Objektif 4.6

RBAC memberikan izin melalui peran (nurse, doctor, billing) sehingga pengelolaan lebih sederhana dan konsisten. **ABAC** akan memakai atribut seperti departemen, waktu, dan lokasi.

47. Jawaban C · Objektif 4.6

ABAC mengevaluasi atribut subjek, objek, dan lingkungan sehingga sangat fleksibel untuk kebijakan kontekstual. Semakin banyak atribut, semakin kompleks pengujian kebijakannya.

48. Jawaban A · Objektif 4.6

JIT access memberi hak istimewa sementara setelah persetujuan dan mencabutnya otomatis, mengurangi jendela penyalahgunaan. Hak permanen dan password bersama melanggar least privilege.

49. Jawaban C · Objektif 4.6

FIDO2/passkey memakai kriptografi kunci publik yang terikat pada origin, sehingga tidak dapat di-phish ke domain palsu. SMS OTP rentan SIM swapping dan real-time phishing.

50. Jawaban A · Objektif 4.6

Risk-based/adaptive authentication memicu langkah tambahan hanya saat risiko tinggi (perangkat baru, lokasi anomali). Rotasi password berkala justru mendorong password lemah dan tidak menghentikan credential stuffing.

51. Jawaban C · Objektif 4.6

Service account khusus aplikasi, dengan hak minimal dan kredensial terkelola (rotasi otomatis). Shared admin dan akun pribadi menghilangkan akuntabilitas.

52. Jawaban D · Objektif 4.6

Access review/attestation memastikan hak akses masih sesuai kebutuhan dan kepatuhan. Temuan umum: hak berlebih (privilege creep) setelah mutasi jabatan.

53. Jawaban B · Objektif 4.6

PAM (Privileged Access Management) menyimpan, memutar, dan mengaudit kredensial istimewa, serta sering menyediakan session recording untuk akun admin.

54. Jawaban B · Objektif 4.6

Automated provisioning (sering via **SCIM**) menyelaraskan akun dengan data HR, mengurangi akun yatim dan kesalahan manual. Proses tahunan terlalu lambat untuk risiko insider.

55. Jawaban D · Objektif 4.7

Guardrails (misalnya OPA/SCP) menolak konfigurasi berbahaya secara otomatis dan konsisten. Review manual tidak dapat diskalakan dan mudah terlewat.

56. Jawaban B · Objektif 4.7

Otomasi mempercepat respons, menstandarkan langkah, dan mengurangi pekerjaan berulang. Otomasi tidak menggantikan logging, tidak menjamin pencegahan total, dan tetap memerlukan persetujuan manusia untuk aksi berisiko.

57. Jawaban D · Objektif 4.7

Otomasi menjadi **single point of failure** bila tidak dipantau; kegagalan harus memicu alert dan ada jalur manual (fallback). Ini juga contoh **technical debt** jika integrasi tidak dipelihara.

58. Jawaban B · Objektif 4.7

Menyimpan secret di repo (termasuk history Git) membuatnya bocor ke siapa pun yang punya akses. Vault dengan akses berbasis identitas dan rotasi menghilangkan hard-coded credentials.

59. Jawaban A · Objektif 4.8

Urutan NIST: **Preparation, Detection & Analysis, Containment/Eradication/Recovery, Post-incident activity (lessons learned)**. Containment selalu sebelum eradication agar penyebaran berhenti lebih dulu.

60. Jawaban B · Objektif 4.8

Mematikan host menghilangkan isi memori (proses, koneksi, kunci). **Isolasi jaringan** menghentikan penyebaran sambil mempertahankan bukti volatil; urutan volatilitas: memori → cache → disk → arsip.

61. Jawaban A · Objektif 4.8

Recovery mengembalikan layanan secara terkontrol dan memvalidasi integritas, lalu **lessons learned** memperbarui prosedur dan kontrol. Preparation adalah fase sebelum insiden.

62. Jawaban A · Objektif 4.8

Chain of custody mendokumentasikan siapa memegang bukti, kapan, dan di mana, sehingga bukti dapat diterima di pengadilan. Tanpa itu, integritas bukti dipertanyakan.

63. Jawaban B · Objektif 4.8

Legal hold menghentikan penghapusan data yang relevan dengan litigasi. Menghapus data setelah hold dapat dianggap obstruction of justice.

64. Jawaban A · Objektif 4.8

Root cause analysis mencari penyebab mendasar (kontrol gagal, proses kurang) agar perbaikan tidak sekadar gejala. Hasilnya masuk ke lessons learned dan perbaikan kontrol.

65. Jawaban B · Objektif 4.8

Threat hunting berangkat dari hipotesis (bukan alert) dan mencari bukti di telemetri. Berbeda dari IR yang merespons insiden yang sudah terdeteksi.

66. Jawaban C · Objektif 4.9

Firewall logs mencatat 5-tuple (source/dest IP, port, protokol) dan aksi, sehingga dapat mengidentifikasi host asal. DNS log membantu bila hanya domain yang diketahui.

67. Jawaban C · Objektif 4.9

Packet capture/protocol analyzer (Wireshark, tcpdump) menyimpan isi paket sehingga sesi dapat direkonstruksi. NetFlow hanya metadata, SIEM menampilkan log/alert.

68. Jawaban C · Objektif 4.9

EDR telemetry memberi process tree dan command line, sedangkan **event logs** memberi logon/audit. Menggabungkan keduanya menghasilkan timeline yang koheren.

69. Jawaban C · Objektif 4.9

Log aggregation mengirim log ke SIEM/arsip terpusat dengan retensi sesuai kebijakan, sehingga bukti tetap tersedia dan tahan terhadap penghapusan lokal oleh penyerang.

70. Jawaban A · Objektif 4.9

NetFlow menyimpan statistik byte/paket per aliran sehingga tren volume per host mudah dianalisis. Packet capture penuh terlalu besar untuk analisis jangka panjang.

71. Jawaban A · Objektif 4.8

Pemulihan dari **backup teruji** adalah jalur utama; membayar tidak menjamin data kembali dan mendanai kejahatan. Keputusan harus melibatkan manajemen, hukum, dan asuransi.

72. Jawaban C · Objektif 4.5

Egress filtering mencegah host terinfeksi berkomunikasi dengan C2 dan mempersulit exfiltration. Ingress filtering melindungi dari koneksi masuk, tetapi tidak membatasi komunikasi keluar.

73. Jawaban B · Objektif 4.5

Script block logging merekam isi skrip, **constrained language mode** membatasi API, dan **EDR** mendeteksi perilaku mencurigakan. Membatasi ke admin saja tidak cukup karena akun admin juga bisa dicuri.

74. Jawaban B · Objektif 4.3

Akses ke file sensitif seperti /etc/shadow memungkinkan pengguna biasa menaikkan hak (misalnya crack hash lalu su). Ini eskalasi privilege lokal akibat permission yang salah.

75. Jawaban D · Objektif 4.1

WPS PIN rentan brute force (Pixie Dust/offline attack) dan harus dimatikan. WPA3, 802.1X, dan PMF justru meningkatkan keamanan.

76. Jawaban C · Objektif 4.2

Server tidak terinventarisasi adalah **shadow asset**; diperlukan **discovery** rutin dan **NAC/802.1X** agar perangkat tak terdaftar tidak dapat terhubung. Ini juga masalah change management.

77. Jawaban A · Objektif 4.6

Token fisik adalah faktor **possession** (something you have). Password = knowledge, biometrik = inherence, lokasi = location-based (bukan faktor utama dalam MFA klasik).

78. Jawaban C · Objektif 4.8

Containment membatasi dampak dan menghentikan penyebaran. Eradication menghilangkan akar masalah (malware, backdoor), recovery mengembalikan layanan normal.

Kunci Domain 5 — Security Program Management and Oversight

1. B	2. C	3. D	4. C	5. C	6. D	7. D	8. A	9. D	10. D
11. C	12. A	13. A	14. D	15. A	16. B	17. A	18. B	19. B	20. B
21. D	22. D	23. A	24. B	25. B	26. A	27. C	28. B	29. C	30. C
31. D	32. C	33. A	34. C	35. B	36. A	37. B	38. C	39. A	40. D
41. D	42. D	43. B	44. D	45. B	46. D	47. A	48. A	49. D	50. B

1. Jawaban B · Objektif 5.1

Policy menyatakan maksud dan arah manajemen (apa dan mengapa), sedangkan **procedure** menjelaskan langkah operasional (bagaimana). **Standard** berisi persyaratan spesifik yang wajib, **guideline** bersifat rekomendasi.

2. Jawaban C · Objektif 5.1

AUP menetapkan penggunaan yang diizinkan dan larangan, termasuk konsekuensi pelanggaran. SLA mengatur tingkat layanan, BPA mengatur kemitraan bisnis.

3. Jawaban D · Objektif 5.1

Data retention policy menetapkan masa simpan berdasarkan kebutuhan bisnis dan regulasi, serta metode penghapusan. Ini juga mendukung e-discovery dan mengurangi risiko penyimpanan berlebih.

4. Jawaban C · Objektif 5.1

Change management policy menetapkan proses persetujuan, pengujian, jadwal, dan backout plan. Tujuannya mencegah perubahan tidak terkontrol yang mengganggu keamanan dan ketersediaan.

5. Jawaban C · Objektif 5.1

Exception adalah penyimpangan resmi dan terdokumentasi dari kebijakan, dengan pemilik risiko, kontrol kompensasi, dan tanggal kedaluwarsa. Tanpa itu, penyimpangan menjadi pelanggaran tak terkelola.

6. Jawaban D · Objektif 5.1

Security steering committee (dewan tata kelola) menyetujui kebijakan dan menerima risiko residual. Administrator menjalankan kontrol, pen tester menguji, help desk menangani operasional.

7. Jawaban D · Objektif 5.1

Standard bersifat spesifik, terukur, dan wajib (AES-256). Pernyataan komitmen adalah policy, langkah operasional adalah procedure, dan saran adalah guideline.

8. Jawaban A · Objektif 5.1

Gap analysis memetakan perbedaan kontrol, lalu kebijakan diselaraskan melalui proses tata kelola dengan persetujuan manajemen. Membiarkan aturan ganda menciptakan celah dan kebingungan audit.

9. Jawaban D · Objektif 5.1

Click rate dan **reporting rate** pada simulasi phishing menunjukkan perilaku nyata, bukan sekadar kehadiran. Metrik input (jam pelatihan) tidak membuktikan efektivitas.

10. Jawaban D · Objektif 5.2

Residual risk adalah sisa risiko setelah kontrol diterapkan. **Inherent risk** adalah risiko sebelum kontrol; manajemen harus menyetujui residual risk yang tersisa.

11. Jawaban C · Objektif 5.2

SLE = Asset Value × Exposure Factor = $200,000 × 0.25 = $50,000. **ALE = SLE × ARO = $50,000 × 0.5 = $25,000** (ARO 0,5 karena sekali per dua tahun).

12. Jawaban A · Objektif 5.2

Transfer memindahkan dampak finansial ke pihak lain (asuransi, kontrak). Risiko operasional dan reputasi tetap ada, sehingga kontrol teknis tidak boleh dihapus.

13. Jawaban A · Objektif 5.2

Avoidance menghilangkan aktivitas yang menimbulkan risiko. Ini berbeda dari mitigation yang mengurangi kemungkinan/dampak, dan acceptance yang menerima risiko.

14. Jawaban D · Objektif 5.2

Risk acceptance dipilih ketika biaya kontrol lebih besar dari dampak yang diperkirakan, dan keputusan itu harus terdokumentasi. Ini bukan kelalaian selama ada analisis dan persetujuan.

15. Jawaban A · Objektif 5.2

Risk register adalah catatan hidup berisi risiko, pemilik, skor, dan rencana penanganan. Dokumen ini menjadi dasar pelaporan ke manajemen dan audit.

16. Jawaban B · Objektif 5.2

Qualitative memakai skala subjektif (low/medium/high) dan cepat diterapkan. **Quantitative** memakai nilai moneter seperti SLE/ALE dan membutuhkan data lebih banyak.

17. Jawaban A · Objektif 5.2

Risk appetite adalah tingkat risiko yang bersedia diambil organisasi; **risk tolerance** adalah variasi yang dapat diterima di sekitar appetite tersebut. RTO berkaitan dengan ketersediaan, bukan selera risiko.

18. Jawaban B · Objektif 5.2

KRI (Key Risk Indicator) memberi peringatan dini tentang memburuknya risiko sehingga tindakan dapat diambil sebelum menjadi insiden. Ini berbeda dari KPI yang mengukur kinerja.

19. Jawaban B · Objektif 5.2

Lingkungan yang berubah cepat membutuhkan **continuous risk assessment** agar risiko baru (konfigurasi berubah, aset baru) segera terdeteksi. Penilaian tahunan saja akan tertinggal.

20. Jawaban B · Objektif 5.2

Risiko di kuadran likelihood tinggi/impact tinggi menjadi prioritas utama. Keputusan tetap harus melibatkan pemilik risiko, tetapi menunda tanpa alasan kuat tidak dapat diterima.

21. Jawaban D · Objektif 5.3

Due diligence menilai risiko vendor sebelum kontrak melalui kuesioner, sertifikasi, dan laporan audit. Hasilnya menentukan apakah kontrol tambahan atau klausul kontrak diperlukan.

22. Jawaban D · Objektif 5.3

Right-to-audit memberi hak untuk mengaudit atau meminta bukti kepatuhan vendor. NDA mengatur kerahasiaan, SLA mengatur tingkat layanan, indemnification mengatur ganti rugi.

23. Jawaban A · Objektif 5.3

MOU (Memorandum of Understanding) menyatakan niat dan pemahaman bersama, umumnya tidak mengikat secara hukum. **MOA** lebih formal dan spesifik; **BPA** mengatur kemitraan bisnis; **SOW** merinci pekerjaan.

24. Jawaban B · Objektif 5.3

Vendor lock-in membuat organisasi sulit berpindah penyedia, sehingga posisi negosiasi dan ketahanan melemah. Mitigasi: standar data terbuka, exit plan, dan multi-vendor untuk fungsi kritis.

25. Jawaban B · Objektif 5.3

Subcontractor/fourth-party memperluas rantai pasok tanpa penilaian, sehingga kontrol dan kepatuhan tidak diketahui. Kontrak harus mewajibkan persetujuan dan pengungkapan subkontraktor.

26. Jawaban A · Objektif 5.3

SOC 2 Type II menilai efektivitas kontrol selama periode tertentu oleh auditor independen. Self-assessment dan materi pemasaran tidak membuktikan operasi kontrol sehari-hari.

27. Jawaban C · Objektif 5.3

Kewajiban notifikasi insiden harus tertulis dalam **kontrak/SLA** (sering sebagai security addendum) agar dapat ditegakkan. AUP mengatur pengguna internal, bukan vendor.

28. Jawaban B · Objektif 5.3

Risiko harus didokumentasikan dan diputuskan oleh pemilik risiko; kontrol kompensasi (segmentasi, monitoring, enkripsi) atau vendor alternatif dapat dipertimbangkan. Jaminan lisan bukan bukti.

29. Jawaban C · Objektif 5.3

DPA mengatur pemrosesan data pribadi antara controller dan processor, termasuk tujuan, keamanan, dan subprocessor. NDA hanya mengatur kerahasiaan informasi.

30. Jawaban C · Objektif 5.4

Controller menentukan tujuan dan cara pemrosesan; **processor** memproses atas nama controller; **data subject** adalah individu yang datanya diproses. Kewajiban utama kepatuhan berada pada controller.

31. Jawaban D · Objektif 5.4

HIPAA mengatur perlindungan **PHI** (protected health information) di sektor kesehatan AS. PCI DSS untuk data kartu pembayaran, SOX untuk pelaporan keuangan, FERPA untuk data pendidikan.

32. Jawaban C · Objektif 5.4

PCI DSS menetapkan persyaratan untuk organisasi yang menangani data kartu pembayaran. ISO 27001 adalah standar sistem manajemen keamanan informasi, bukan khusus kartu.

33. Jawaban A · Objektif 5.4

SOC 2 Type I menilai desain kontrol pada satu titik waktu; **Type II** menilai efektivitas operasi selama periode. Pen test menguji eksploitabilitas, bukan kepatuhan kontrol.

34. Jawaban C · Objektif 5.4

NIST CSF mengorganisasi praktik keamanan ke dalam fungsi Identify, Protect, Detect, Respond, Recover (dan Govern pada versi 2.0). Regulasi seperti HIPAA/PCI bersifat wajib untuk cakupan tertentu.

35. Jawaban B · Objektif 5.4

Attestation adalah pernyataan resmi bahwa kontrol memenuhi persyaratan, sering didukung audit. Ini berbeda dari acknowledgment yang hanya menandakan penerimaan dokumen.

36. Jawaban A · Objektif 5.4

Konsekuensi ketidakpatuhan mencakup **denda, sanksi, kerusakan reputasi, kehilangan lisensi, dan dampak kontrak**. Kepatuhan bukan jaminan keamanan, tetapi pelanggaran membawa risiko hukum dan bisnis.

37. Jawaban B · Objektif 5.4

Data subject rights (akses, koreksi, penghapusan, portabilitas) mengharuskan organisasi memiliki proses untuk menemukan dan menghapus data pribadi. Ini memerlukan inventaris data yang baik.

38. Jawaban C · Objektif 5.5

Audit bersifat formal, independen, dan berbasis bukti terhadap kriteria (misalnya ISO 27001, SOC 2). **Assessment** bisa internal dan lebih fleksibel untuk mengukur maturity atau kesiapan.

39. Jawaban A · Objektif 5.5

Temuan audit harus dicatat dengan bukti, ditindaklanjuti pemilik yang jelas, dan diverifikasi ulang. Menghapus temuan adalah pelanggaran integritas audit.

40. Jawaban D · Objektif 5.5

Internal audit/readiness assessment menemukan kekurangan sebelum auditor eksternal datang, memberi waktu perbaikan. Pen test menguji keamanan teknis, bukan kesiapan bukti kepatuhan.

41. Jawaban D · Objektif 5.6

Reporting rate naik dan **click rate turun** menunjukkan pengguna semakin waspada dan mau melaporkan. Mengukur jumlah email terkirim tidak menunjukkan perubahan perilaku.

42. Jawaban D · Objektif 5.6

Tailgating (piggybacking) adalah mengikuti orang berwenang masuk tanpa otorisasi. Mitigasi: access control vestibule, pelatihan, dan kebijakan menantang orang tak dikenal.

43. Jawaban B · Objektif 5.6

BEC mengeksploitasi urgensi dan otoritas; kontrol kuncinya adalah **verifikasi out-of-band** sebelum mengubah data pembayaran. Password kuat tidak mencegah transfer yang salah.

44. Jawaban D · Objektif 5.6

Gamification meningkatkan partisipasi melalui elemen permainan. Simulasi phishing melatih deteksi, role-based training menyesuaikan materi dengan pekerjaan.

45. Jawaban B · Objektif 5.6

Reporting culture memungkinkan deteksi dini dan respons cepat. Program awareness harus mempermudah pelaporan (tombol report) dan memberi umpan balik positif, bukan menghukum kesalahan.

46. Jawaban D · Objektif 5.6

Clean desk/clear screen mencegah dokumen dan layar terbuka ditinggal tanpa pengawasan. Ini kontrol operasional sederhana yang sering diuji dalam audit fisik.

47. Jawaban A · Objektif 5.6

Pekerja remote menghadapi risiko jaringan tidak tepercaya (evil twin, sniffing), sehingga perlu VPN, verifikasi jaringan, dan kebijakan perangkat. Topik fisik seperti rack server tidak relevan bagi mereka.

48. Jawaban A · Objektif 5.6

Scenario-based training melatih karyawan mengenali tanda-tanda dan melapor melalui kanal yang jelas (termasuk anonim). Sekadar menandatangani kebijakan tidak mengubah kemampuan mendeteksi.

49. Jawaban D · Objektif 5.6

Reporting rate penting karena laporan pengguna mempercepat respons terhadap serangan nyata. Program harus mempermudah pelaporan dan memberi umpan balik, bukan menghukum.

50. Jawaban B · Objektif 5.1

SLA menetapkan tingkat layanan terukur (uptime, waktu respons, sanksi). MOU menyatakan niat, NDA kerahasiaan, AUP penggunaan yang dapat diterima.

BAGIAN III — SOAL PERFORMA (PBQ)

Soal Performa (Performance-Based Questions)

Di ujian SY0-701, sebagian soal berbentuk **PBQ**: Anda diminta mengonfigurasi, mencocokkan, mengurutkan, atau menganalisis, bukan sekadar memilih A/B/C/D. Latihan di bawah ini meniru gaya tersebut. Kerjakan di kertas atau file terpisah, lalu bandingkan dengan **jawaban model**.

> *Tips: pada PBQ asli, baca instruksi dengan teliti (misalnya "pilih tiga" atau "urutkan"), dan jangan menghabiskan terlalu banyak waktu pada satu PBQ.*

PBQ 1 — Kategori dan tipe kontrol

Skenario: Sebuah perusahaan menerapkan kontrol berikut:

1. Badge reader pada pintu data center
2. Kebijakan penggunaan kata sandi yang ditandatangani CFO
3. Kamera CCTV di lobi
4. Restore database dari backup setelah insiden
5. Pelatihan phishing tahunan
6. Pagar setinggi tiga meter
7. Peringatan "aplikasi ini diblokir oleh kebijakan perusahaan" saat pengguna membuka aplikasi terlarang
8. Isolasi VLAN untuk mesin produksi yang tidak bisa dipatch

Tugas: Untuk setiap kontrol, tentukan **kategori** (technical, managerial, operational, physical) dan **tipe** (preventive, deterrent, detective, corrective, compensating, directive).

Jawaban model:

#	Kategori	Tipe
1	Technical	Preventive
2	Managerial	Directive
3	Physical	Detective (juga deterrent)
4	Operational	Corrective
5	Managerial	Directive (preventive terhadap perilaku)
6	Physical	Deterrent
7	Technical	Preventive
8	Technical	Compensating

Pembahasan: Kategori menunjukkan "dari mana" kontrol berasal (orang/proses, teknologi, fisik), sedangkan tipe menunjukkan "apa efeknya". Satu kontrol dapat punya lebih dari satu tipe; pilih yang paling dominan sesuai konteks.

PBQ 2 — Urutan incident response

Skenario: Ransomware terdeteksi menyebar di 40 endpoint dan dua file server. Anda mendapat daftar tindakan berikut (tidak berurutan):

- A. Memulihkan data dari backup dan memverifikasi integritas
- B. Mengisolasi segmen jaringan yang terinfeksi dan mematikan berbagi file
- C. Menghapus malware, menghapus persistence, dan mereset kredensial
- D. Menganalisis log, sampel malware, dan menentukan ruang lingkup
- E. Menyusun laporan akhir dan memperbarui playbook

- F. Mempersiapkan tim, kontak, dan akses ke tool forensik sebelum insiden
- G. Mendeteksi alert EDR dan mengonfirmasi insiden

Tugas: Urutkan tindakan sesuai fase IR dan beri nama fasenya.

Jawaban model:

F (Preparation) → **G** (Detection & Analysis) → **D** (Analysis/scope) → **B** (Containment) → **C** (Eradication) → **A** (Recovery) → **E** (Post-incident/Lessons learned).

Pembahasan: Deteksi belum tentu sama dengan analisis; konfirmasi dan penentuan ruang lingkup harus mendahului containment agar tidak memutus bukti. Eradication dilakukan setelah penyebaran berhenti, dan recovery harus divalidasi sebelum layanan dibuka penuh.

PBQ 3 — Desain aturan firewall untuk aplikasi tiga tier

Skenario: Anda memiliki:

- ALB publik 203.0.113.10 (load balancer)
- Web server 10.10.1.20
- App server 10.10.2.30
- Database 10.10.3.40

Tugas: Tulis aturan firewall minimum (source → destination, port, protokol, aksi) agar pengguna internet dapat mengakses aplikasi dan setiap tier hanya dapat berbicara dengan tier berikutnya.

Jawaban model:

#	Source	Destination	Port/Proto	Aksi
1	Any	203.0.113.10	443/TCP	Allow
2	ALB	10.10.1.20	443/TCP	Allow
3	10.10.1.20	10.10.2.30	8080/TCP	Allow
4	10.10.2.30	10.10.3.40	5432/TCP	Allow
5	Any	Any	Any	Deny

Pembahasan: Prinsipnya **default deny** + least privilege: database tidak boleh menerima koneksi langsung dari internet atau dari web tier, dan tidak ada aturan "any → any" di dalam. Untuk produksi, tambahkan logging, aturan egress terbatas, dan akses administrasi melalui bastion.

PBQ 4 — Cocokkan indikator dengan serangan

Skenario: Temuan dari SIEM:

9. UNION SELECT pada parameter id di URL
10. Ribuan percobaan login dengan password sama ke banyak akun
11. Login sukses dari dua negara dalam 10 menit
12. ARP reply berulang yang memetakan gateway ke MAC baru
13. Lonjakan trafik UDP ke port 53 dari banyak sumber ke satu host
14. Proses powershell.exe mengambil script dari IP eksternal dan berjalan di memori

Tugas: Cocokkan setiap temuan dengan jenis serangan dan satu kontrol mitigasi utama.

Jawaban model:

15. **SQL injection** → parameterized query + WAF.
16. **Password spraying** → lockout/rate limiting + MFA.
17. **Impossible travel / credential theft** → risk-based auth, cabut sesi, MFA.
18. **ARP poisoning** → dynamic ARP inspection + port security.
19. **DNS amplification DDoS** → rate limiting, anycast/scrubbing, tutup resolver terbuka.

20. **Fileless malware** → EDR, script block logging, PowerShell constrained mode.

Pembahasan: Indikator harus dikaitkan dengan vektor dan kontrol yang spesifik. Menjawab "pasang antivirus" untuk fileless menunjukkan pemahaman yang kurang; EDR dan logging perilaku lebih tepat.

PBQ 5 — Pilih respons risiko

Skenario: Sebuah perusahaan memiliki lima risiko:

21. Kebocoran data pelanggan yang dapat ditanggung polis asuransi siber
22. Layanan legacy berisiko tinggi yang bisa dihentikan tanpa dampak bisnis
23. Kerentanan pada server internal yang dapat ditambal minggu depan
24. Risiko kecil pada printer lobby yang biaya kontrolnya lebih besar dari dampaknya
25. Risiko pihak ketiga yang tidak dapat dikendalikan, tetapi kontraknya mengalihkan tanggung jawab finansial

Tugas: Tentukan respons risiko (avoid, mitigate, transfer, accept) dan jelaskan alasannya.

Jawaban model:

26. **Transfer** — asuransi memindahkan dampak finansial.
27. **Avoid** — hentikan layanan.
28. **Mitigate** — patch dan kontrol tambahan.
29. **Accept** — dokumentasikan dengan persetujuan pemilik risiko.
30. **Transfer** (sebagian) — klausul kontrak/indemnification; risiko operasional tetap dipantau.

Pembahasan: Respons harus sesuai konteks; "accept" bukan berarti mengabaikan, melainkan keputusan terdokumentasi berdasarkan analisis biaya-manfaat. Risiko residual tetap dicatat di risk register.

PBQ 6 — Cocokkan konsep kriptografi

Skenario: Kebutuhan berikut:

31. Membuktikan dokumen tidak berubah dan berasal dari pengirim tertentu
32. Memulihkan data bila admin lupa password enkripsi
33. Menyimpan password pengguna agar tidak bisa dibalik dan tahan rainbow table
34. Mengganti nomor kartu kredit pada sistem kasir agar tidak menyimpan PAN asli
35. Melindungi data saat dikirim antara browser dan server
36. Menyimpan kunci root CA secara offline dan tahan manipulasi

Tugas: Pilih konsep/alat yang paling tepat untuk setiap kebutuhan.

Jawaban model:

37. **Digital signature** (private key pengirim + verifikasi public key).
38. **Key escrow**.
39. **Hashing + salt** (misalnya Argon2/bcrypt).
40. **Tokenization**.
41. **TLS**.
42. **HSM offline**.

Pembahasan: Perhatikan tujuan: integritas + autentikasi + non-repudiation = signature; kerahasiaan = enkripsi; verifikasi satu arah = hash. Tokenization berbeda dari enkripsi karena nilai asli tidak dapat direkonstruksi tanpa vault.

PBQ 7 — Analisis header email

Skenario: Email mengaku dari cfo@perusahaan.co.id memiliki hasil autentikasi:

- SPF: **fail**
- DKIM: **none**
- DMARC: **none**
- Reply-To: cfo.perusahaan@gmail.com

Tugas: Sebutkan tiga indikasi phishing dan tiga tindakan yang harus diambil.

Jawaban model:

Indikasi: (1) SPF gagal berarti pengirim tidak berwenang untuk domain tersebut; (2) tidak ada DKIM/DMARC sehingga tidak ada jaminan integritas dan kebijakan; (3) Reply-To berbeda domain — ciri BEC.

Tindakan: (1) jangan membalas atau membuka lampiran; (2) laporkan ke tim keamanan dan teruskan header asli; (3) verifikasi melalui nomor telepon yang diketahui, serta blokir pengirim/domain di gateway.

Pembahasan: SPF memeriksa IP pengirim, DKIM memverifikasi tanda tangan, DMARC memberi kebijakan dan alignment. Ketiganya saling melengkapi; ketiadaan DMARC membuat email palsu lebih mudah lolos.

PBQ 8 — Hardening Wi-Fi kantor

Skenario: Kantor memiliki jaringan korporat untuk karyawan dan jaringan tamu. Perangkat lama masih mendukung WPA2. Anda harus mengonfigurasi SSID korporat dan tamu.

Tugas: Tentukan konfigurasi minimum untuk SSID korporat dan tamu.

Jawaban model:

- **Korporat:** WPA3-Enterprise (transisi WPA2-Enterprise bila perlu), 802.1X/EAP-TLS dengan sertifikat perangkat, RADIUS, PMF (802.11w) aktif, WPS dimatikan, SSID terpisah + VLAN, management frame protection, dan logging ke RADIUS.
- **Tamu:** SSID terpisah, WPA2/WPA3-PSK dengan password yang dirotasi, client isolation, bandwidth limit, captive portal, dan akses hanya ke internet.

Pembahasan: Jangan gunakan PSK untuk karyawan karena kunci bersama tidak dapat dicabut per pengguna. Segmentasi VLAN dan client isolation mencegah tamu mengakses resource internal.

PBQ 9 — Cocokkan protokol IAM

Skenario: Kebutuhan:

43. SSO antar organisasi dengan assertion XML
44. Aplikasi pihak ketiga mengakses API pengguna dengan izin terbatas
45. Autentikasi pengguna pada aplikasi mobile modern dengan token identitas
46. AAA untuk perangkat jaringan dengan enkripsi seluruh payload
47. AAA untuk Wi-Fi dengan dukungan luas
48. Query direktori untuk atribut pengguna

Tugas: Cocokkan dengan protokol yang tepat.

Jawaban model:

49. **SAML 2.0**
50. **OAuth 2.0**
51. **OpenID Connect (OIDC)**
52. **TACACS+**
53. **RADIUS**
54. **LDAP**

Pembahasan: OAuth bukan protokol autentikasi; OIDC menambahkan layer identitas di atas OAuth. RADIUS mengenkripsi password saja, TACACS+ seluruh body dan memisahkan AAA.

PBQ 10 — RTO, RPO, dan strategi backup

Skenario: Sistem penjualan:

- Kehilangan data maksimum yang dapat diterima: 15 menit
- Waktu pemulihan maksimum: 2 jam
- Backup penuh harian pukul 01.00 ke tape, disimpan di lokasi yang sama

Tugas: (a) Tentukan RTO dan RPO. (b) Jelaskan mengapa strategi backup saat ini tidak memenuhi. (c) Usulkan perbaikan.

Jawaban model:

(a) RTO = 2 jam; RPO = 15 menit.

(b) Backup harian berarti RPO hingga 24 jam, jauh melebihi 15 menit; tape di lokasi yang sama tidak terlindung dari bencana dan rawan ikut terenkripsi ransomware.

(c) Terapkan transaction log/continuous backup (atau replikasi), simpan salinan offsite/offline (3-2-1), uji restore berkala, dan siapkan site/warm standby agar RTO 2 jam tercapai.

Pembahasan: RPO menentukan frekuensi backup; RTO menentukan arsitektur pemulihan. Backup yang belum diuji restore tidak dapat dijamin memenuhi RTO.

PBQ 11 — Shared responsibility matrix

Skenario: Perusahaan menggunakan IaaS untuk VM, PaaS untuk aplikasi internal, dan SaaS untuk email.

Tugas: Tentukan siapa (Customer/Provider) yang bertanggung jawab atas: patch OS, patch aplikasi email, konfigurasi IAM, keamanan fisik data center, enkripsi data pelanggan, dan patch runtime PaaS.

Jawaban model:

Item	IaaS	PaaS	SaaS
Patch OS	Customer	Provider	Provider
Patch aplikasi email	—	—	Provider
Konfigurasi IAM	Customer	Customer	Customer
Keamanan fisik	Provider	Provider	Provider
Enkripsi data pelanggan	Customer	Customer	Customer (shared)
Patch runtime	—	Provider	Provider

Pembahasan: Semakin tinggi model layanan, semakin banyak tanggung jawab operasional yang diambil penyedia, tetapi **identitas, akses, dan data** selalu menjadi tanggung jawab pelanggan.

PBQ 12 — Urutan volatilitas bukti

Skenario: Sebuah server Linux dicurigai sebagai host pivot penyerang. Anda harus mengumpulkan bukti tanpa merusaknya.

Tugas: Urutkan sumber bukti dari paling volatil ke paling persisten, dan sebutkan tiga tindakan pertama yang harus dilakukan.

Jawaban model:

Urutan: **register/CPU cache → RAM (proses, koneksi, kunci) → swap/pagefile → disk (file, log) → arsip/backup → konfigurasi jaringan/printout**.

Tiga tindakan pertama:

55. Isolasi host dari jaringan (jangan matikan) dan dokumentasikan waktu.
56. Ambil image memori dengan tool forensik dan catat hash.
57. Buat image disk bit-by-bit (write blocker), catat chain of custody.

Pembahasan: Mematikan host menghilangkan memori dan koneksi aktif. Urutan volatilitas memastikan bukti yang paling mudah hilang diambil lebih dulu, dan setiap langkah harus tercatat untuk menjaga integritas bukti.